

IBS:

Bezpečnost a počítačové sítě

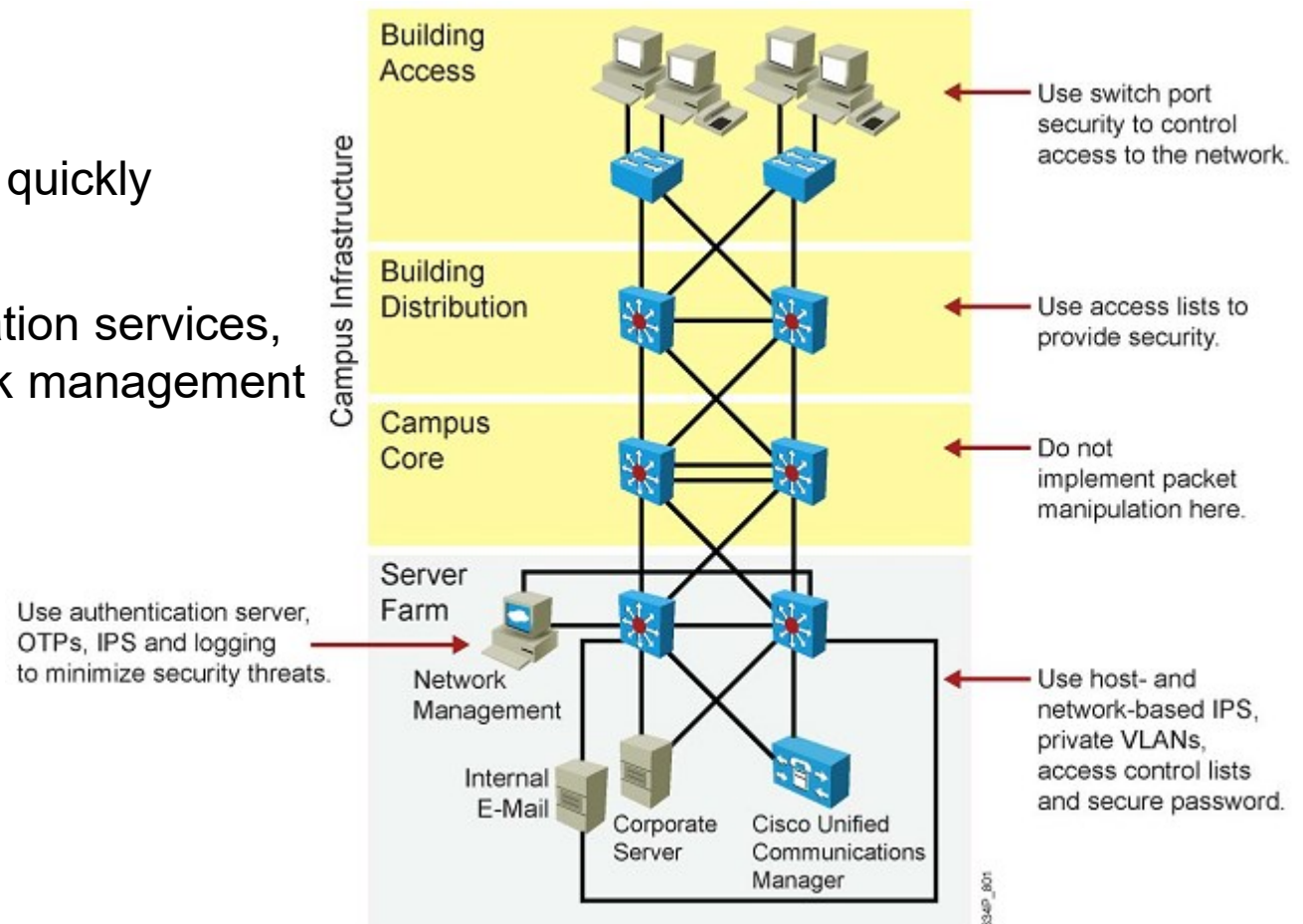
CAM Overflow, DHCP Spoofing, ARP MitM

Brno University of Technology, Faculty of Information Technology
Božetěchova 1/2, 612 66 Brno - Královo Pole
Vladimír Veselý, veselyv@fit.vut.cz

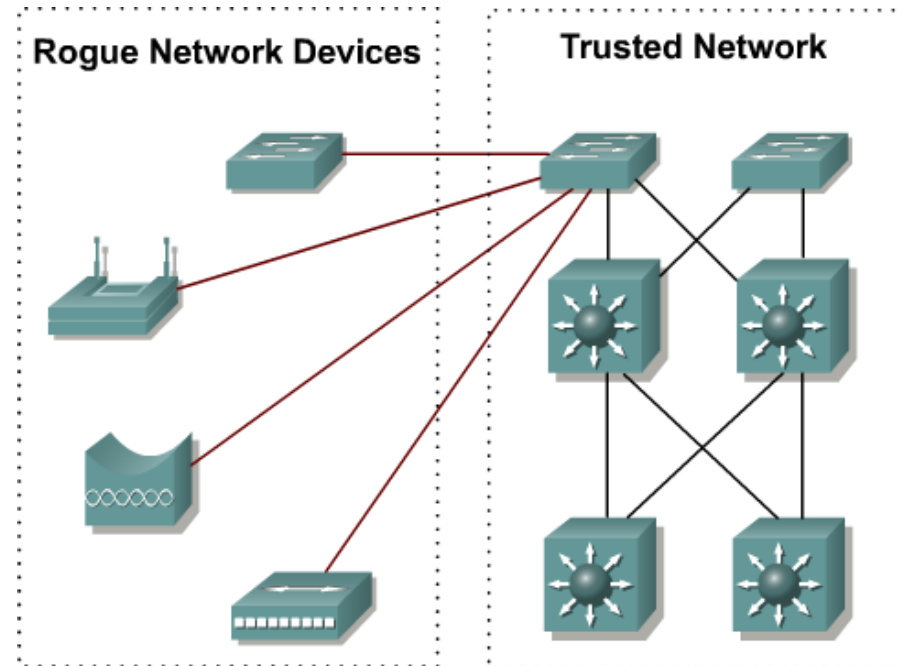


24th March 2025

- **Access**
 - control at port level
- **Distribution**
 - packet filtering
- **Core**
 - switch packets quickly
- **Server farm**
 - provide application services, include network management system.



- Unwanted (and unfortunately unwanted) phenomenon are users plugging **rogue devices** into enterprise network
- Role of access layer switch is to control, secure and limit the access to network
- Several mechanisms are available
 - Port Security
 - 802.1X
 - Network Admission Control



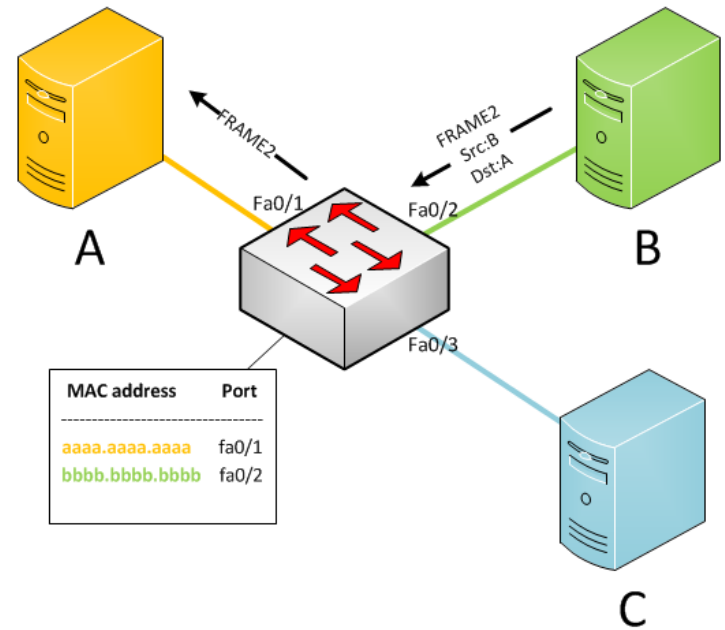
- You should consider the policies of an organization when determining **what level of security and what type of security should be implemented**
- A well-established **security policy** has the characteristics listed above
 - Provides a process for auditing existing network security
 - Provides a general security framework for implementing network security
 - Defines disallowed behaviors toward electronic data
 - Determines which tools and procedures are needed for the organization
 - Communicates consensus among a group of key decision makers and defines responsibilities of users and administrators
 - Defines a process for handling network security incidents
 - Enables an enterprise-wide, all-site security implementation and enforcement plan

- Configure strong system passwords (**enable secret**)
- Restrict management access using ACLs (**deny ip any any log**)
- Secure physical access to the console
 - Console access requires a minimum level of security both physically and logically
- Secure access to vty lines
 - Telnet packets can be read in clear text. SSH is an option, but it has security issues in Version 1. Use SSHv2 instead.
- Configure system warning banners
 - Clearly stating the ownership, usage, access, and protection policies prior to a login aids in stronger prosecution if unauthorized access occurs
- Disable unneeded or unused services
- Trim and minimize the use of CDP/LLDP (**no [cdp | lldp] enable**)
- Secure integrated HTTP daemon where appropriate (**ip http access-class**)
- Configure basic system logging (syslog)
- Secure SNMP (use SNMPv3 with authentication and privacy)
- Limit trunking connections and propagated VLANs (**switchport nonegotiate**)
- Secure the spanning-tree topology (BPDU/Loop/Root Guard, BPDU Filter)

Attack Method	Description	Steps to Mitigation
<i>MAC Layer Attacks</i>		
MAC Address Flooding	Frames with unique, invalid source MAC addresses flood the switch, exhausting content addressable memory (CAM) table space, disallowing new entries from valid hosts. Traffic to valid hosts is subsequently flooded out all ports.	Port security. MAC address VLAN access maps.
<i>VLAN Attacks</i>		
VLAN Hopping	By altering the VLAN ID on packets encapsulated for trunking, an attacking device can send or receive packets on various VLANs, bypassing Layer 3 security measures.	Tighten up trunk configurations and the negotiation state of unused ports. Place unused ports in a common VLAN.
Attacks between Devices on a Common VLAN	Devices might need protection from one another, even though they are on a common VLAN. This is especially true on service-provider segments that support devices from multiple customers.	Implement private VLANs (PVLAN).

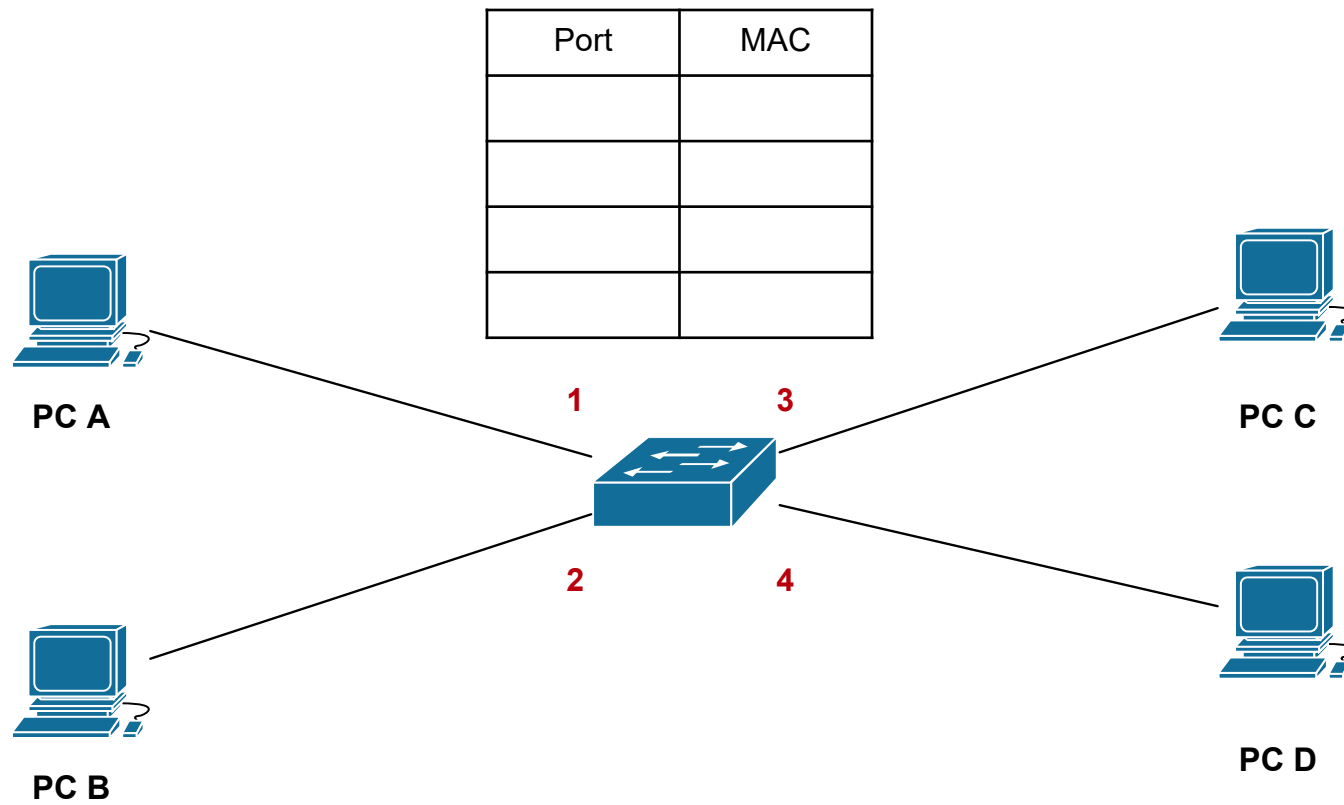
Attack Method	Description	Steps to Mitigation
<i>Spoofing Attacks</i>		
DHCP Starvation and DHCP Spoofing	An attacking device can exhaust the address space available to the DHCP servers for a period of time or establish itself as a DHCP server in man-in-the-middle attacks.	Use DHCP snooping.
Spanning-tree Compromises	Attacking device spoofs the root bridge in the STP topology. If successful, the network attacker can see a variety of frames.	Proactively configure the primary and backup root devices. Enable root guard.
MAC Spoofing	Attacking device spoofs the MAC address of a valid host currently in the CAM table. The switch then forwards frames destined for the valid host to the attacking device.	Use DHCP snooping, port security.
Address Resolution Protocol (ARP) Spoofing	Attacking device crafts ARP replies intended for valid hosts. The attacking device's MAC address then becomes the destination address found in the Layer 2 frames sent by the valid network device.	Use Dynamic ARP Inspection (DAI), DHCP snooping, port security.

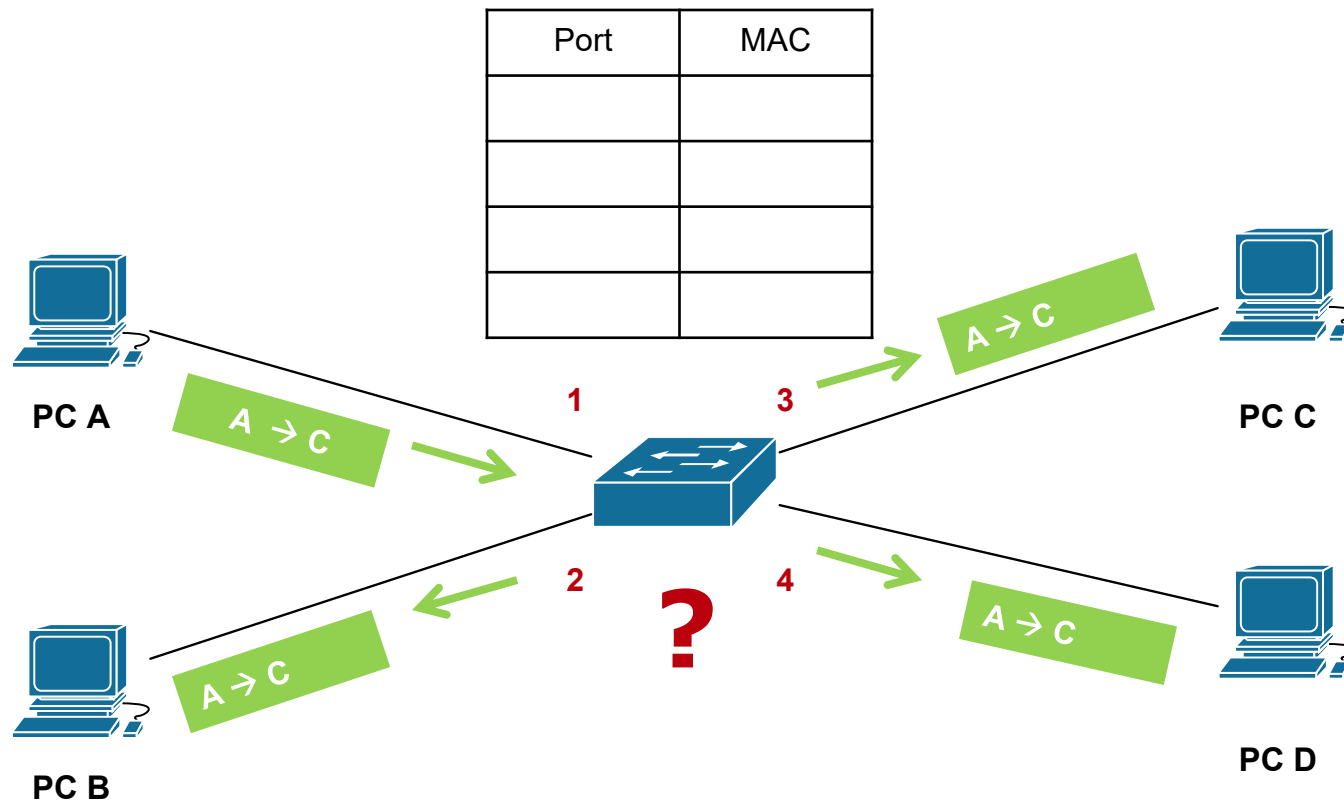
Attack Method	Description	Steps to Mitigation
<i>Switch Device Attacks</i>		
Cisco Discovery Protocol (CDP) Manipulation	Information sent through CDP is transmitted in clear text and unauthenticated, allowing it to be captured and divulge network topology information.	Disable CDP on all ports where it is not intentionally used.
Secure Shell Protocol (SSH) and Telnet Attacks	Telnet packets can be read in clear text. SSH is an option but has security issues in version 1.	Use SSH version 2. Use Telnet with vty ACLs.

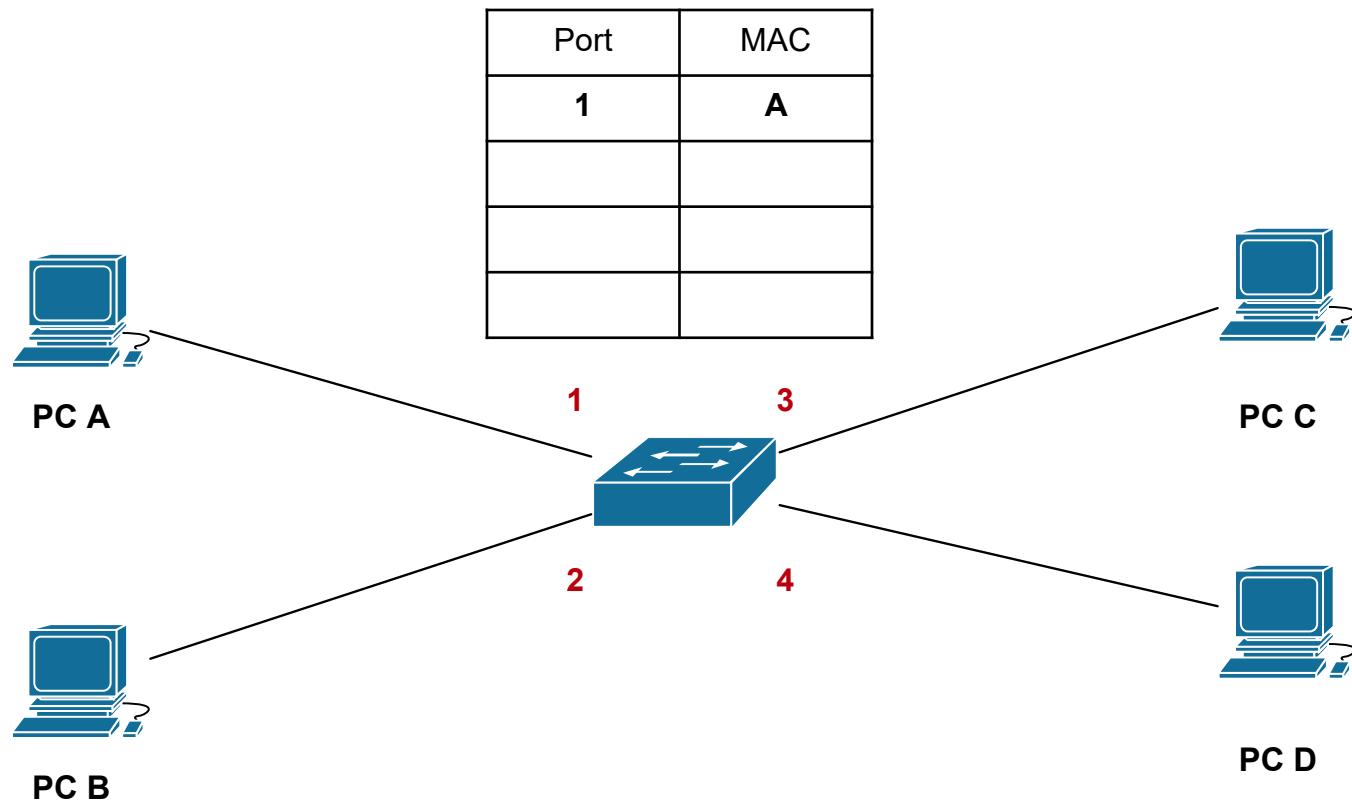


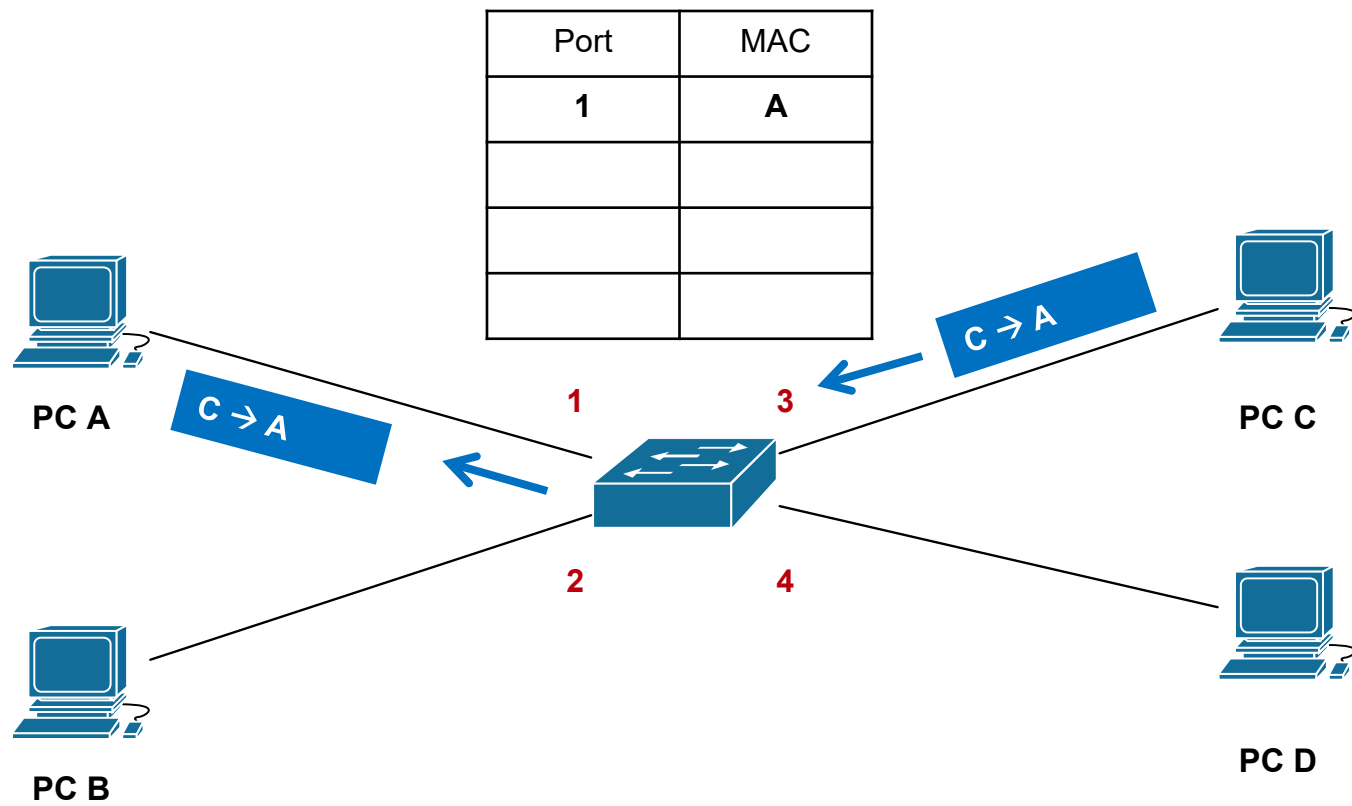
Attack

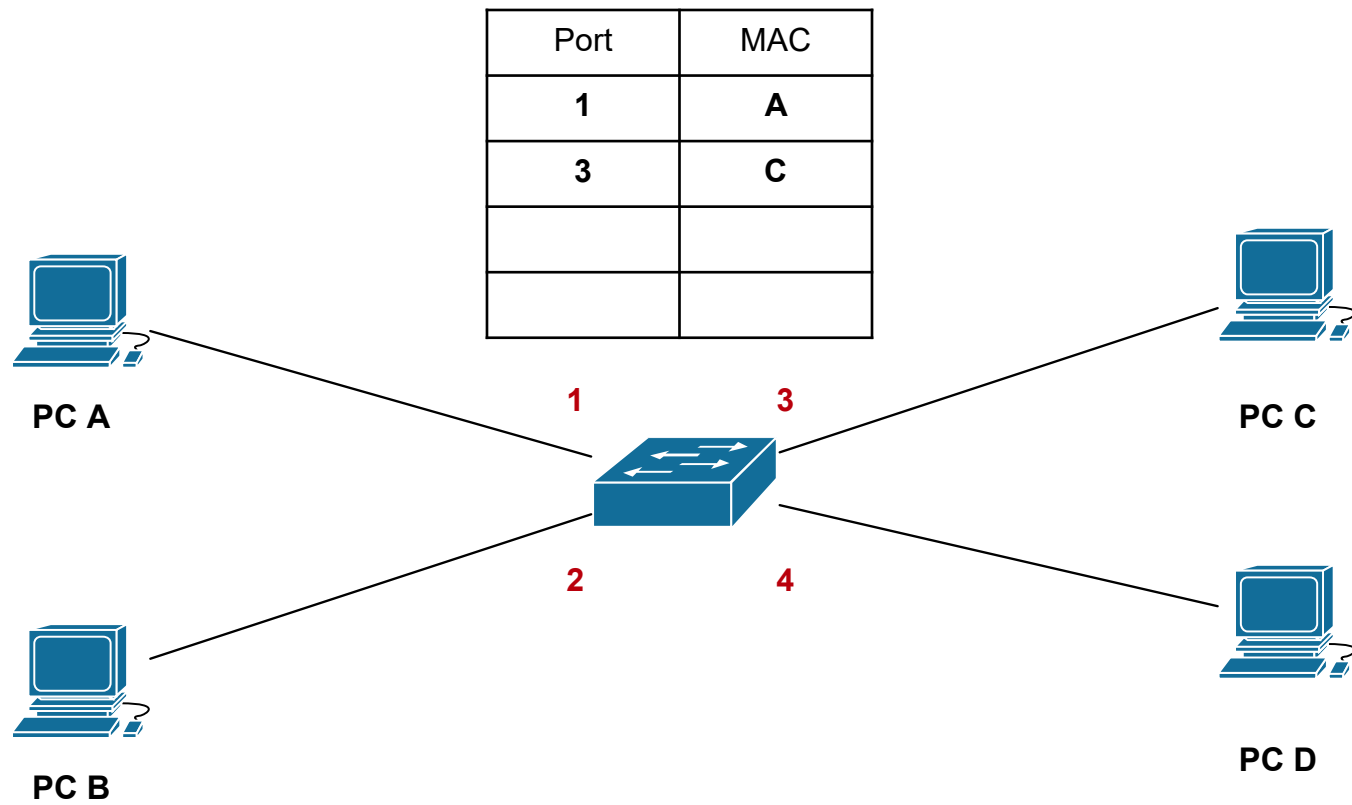
CAM OVERFLOW

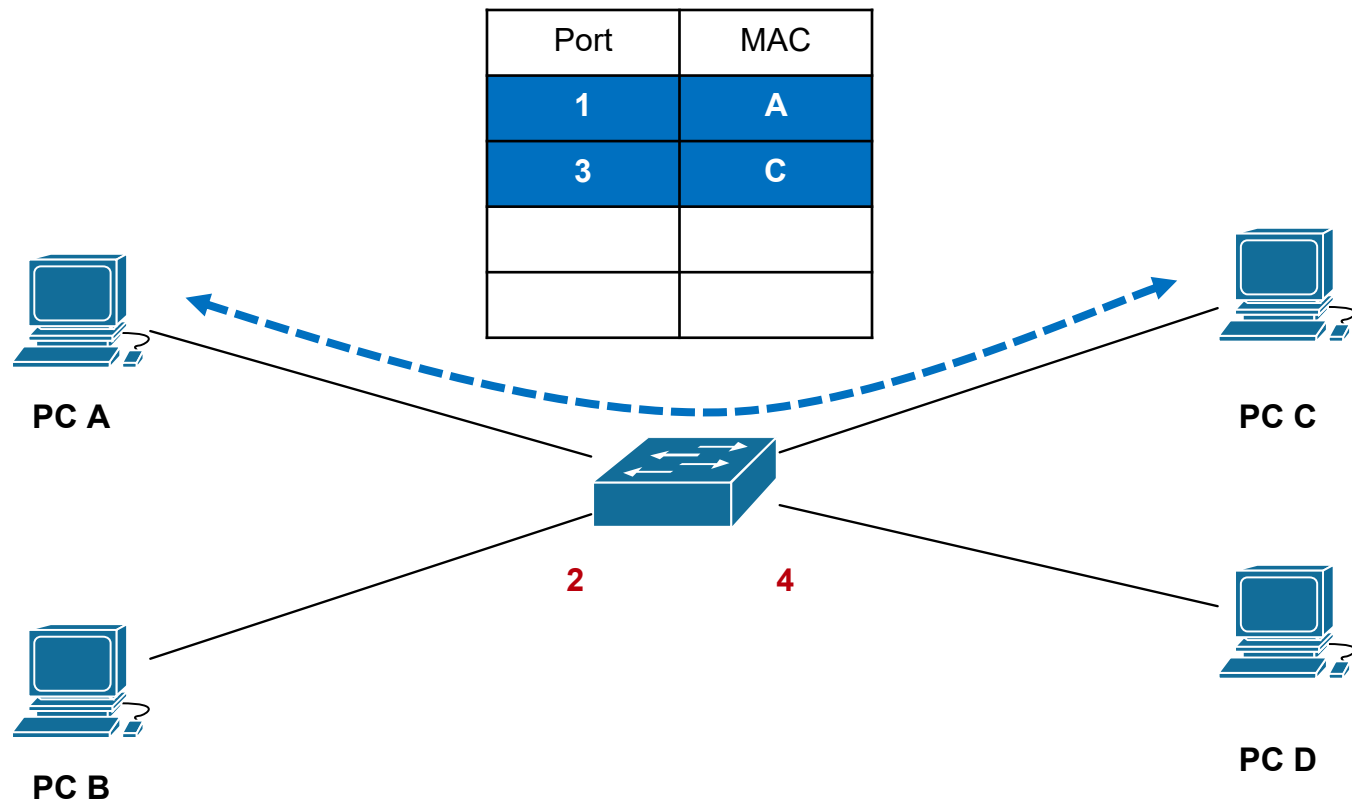


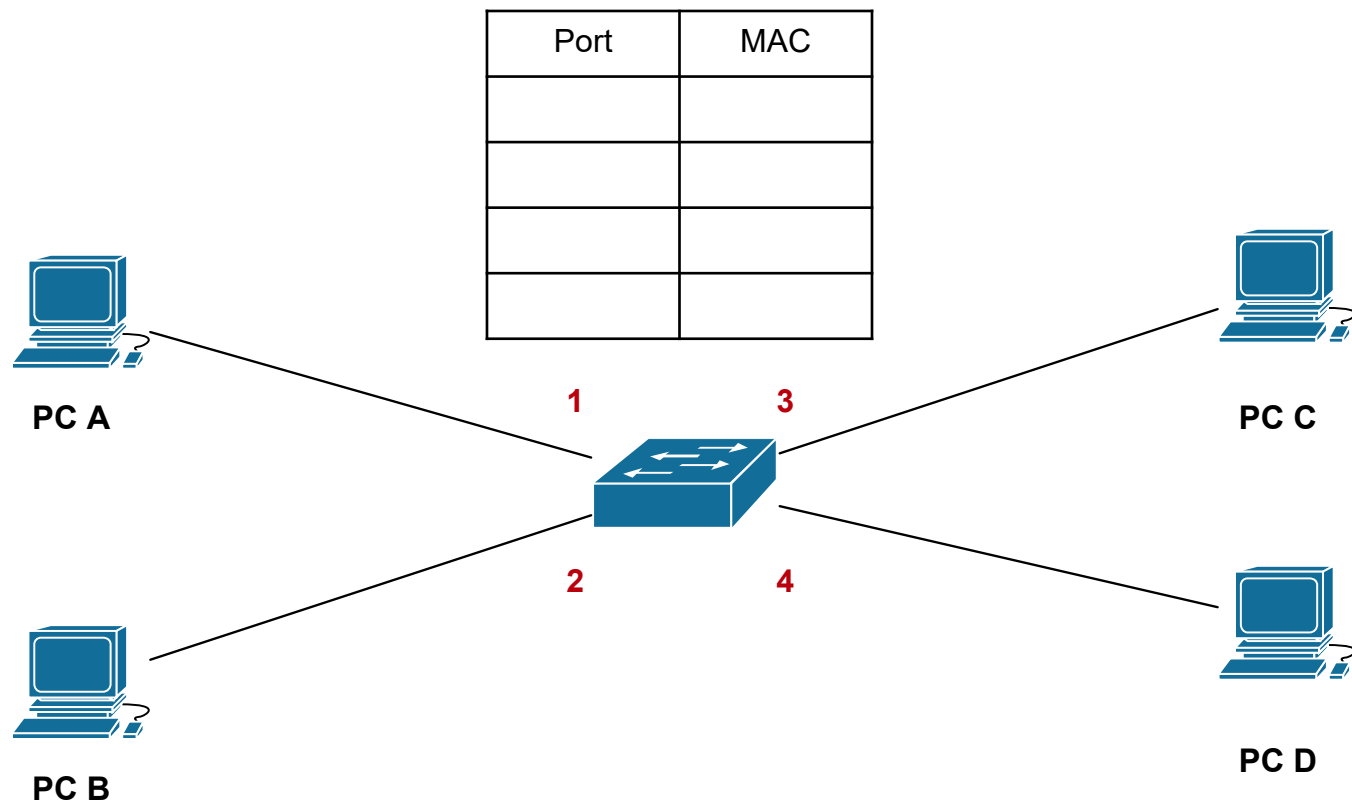


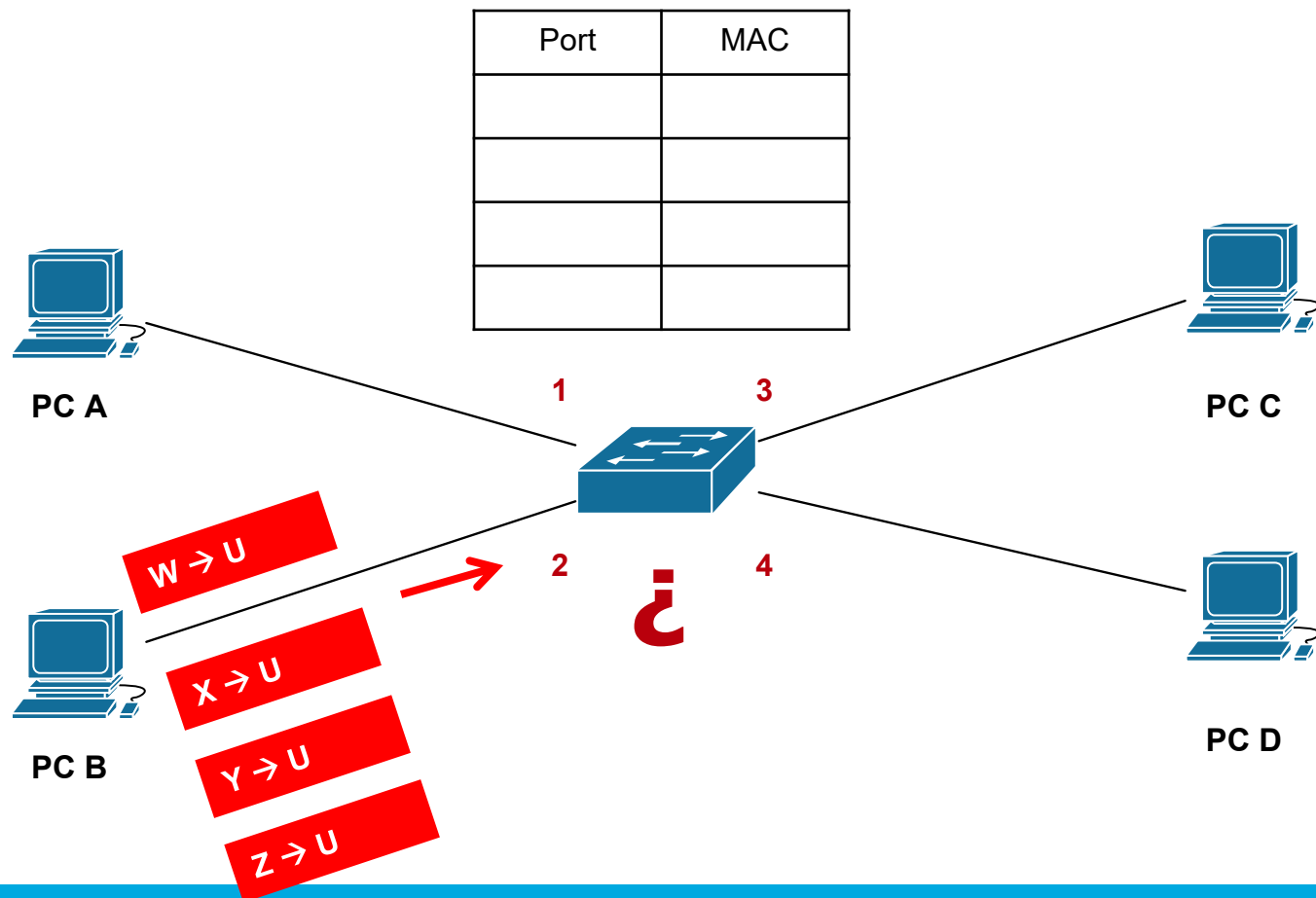


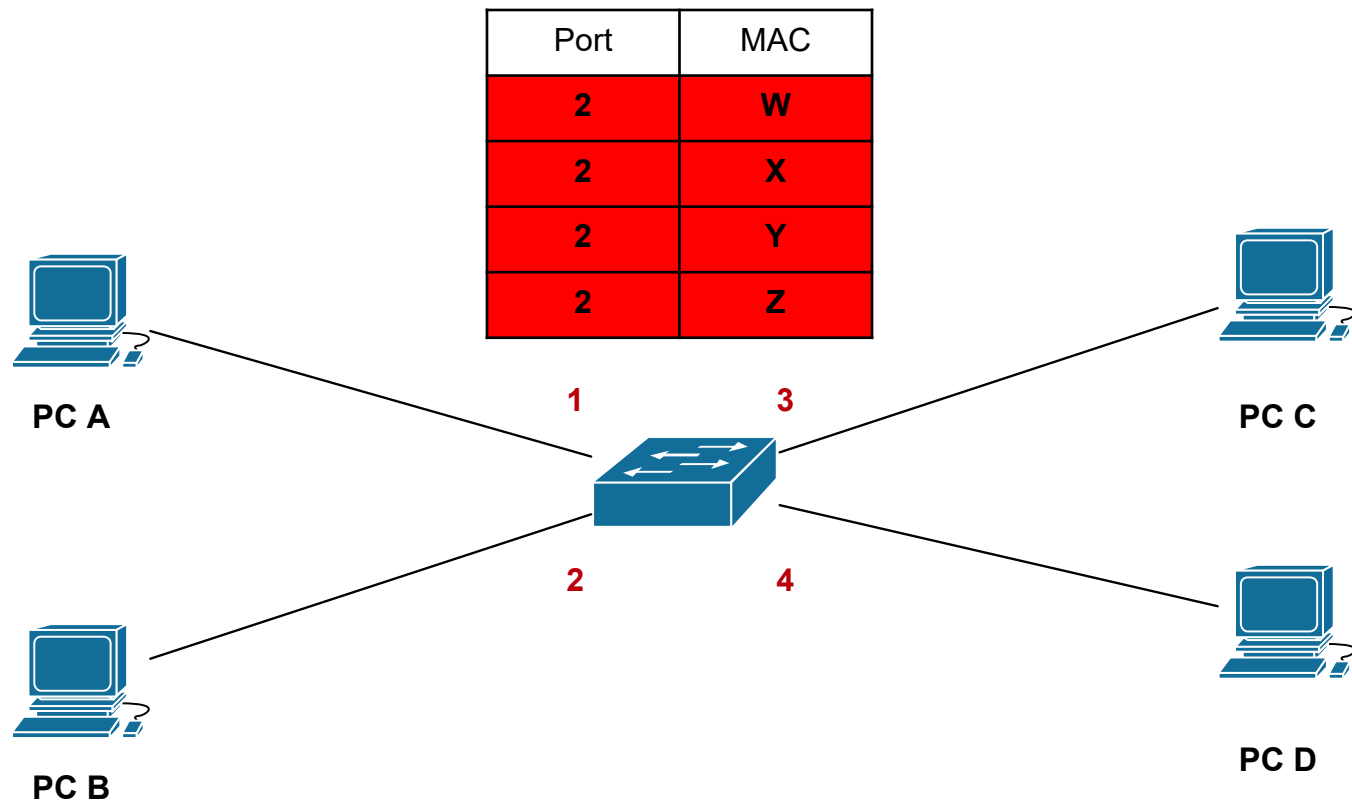


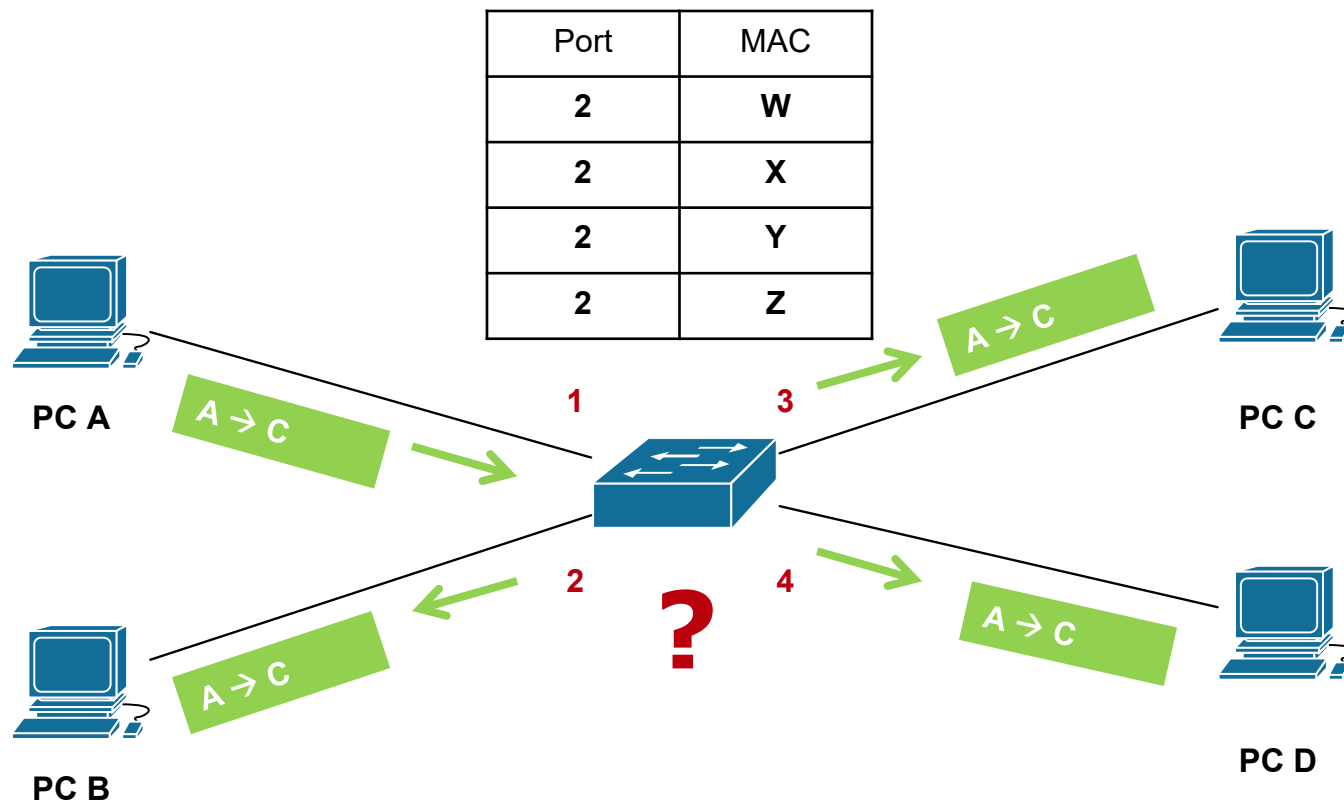


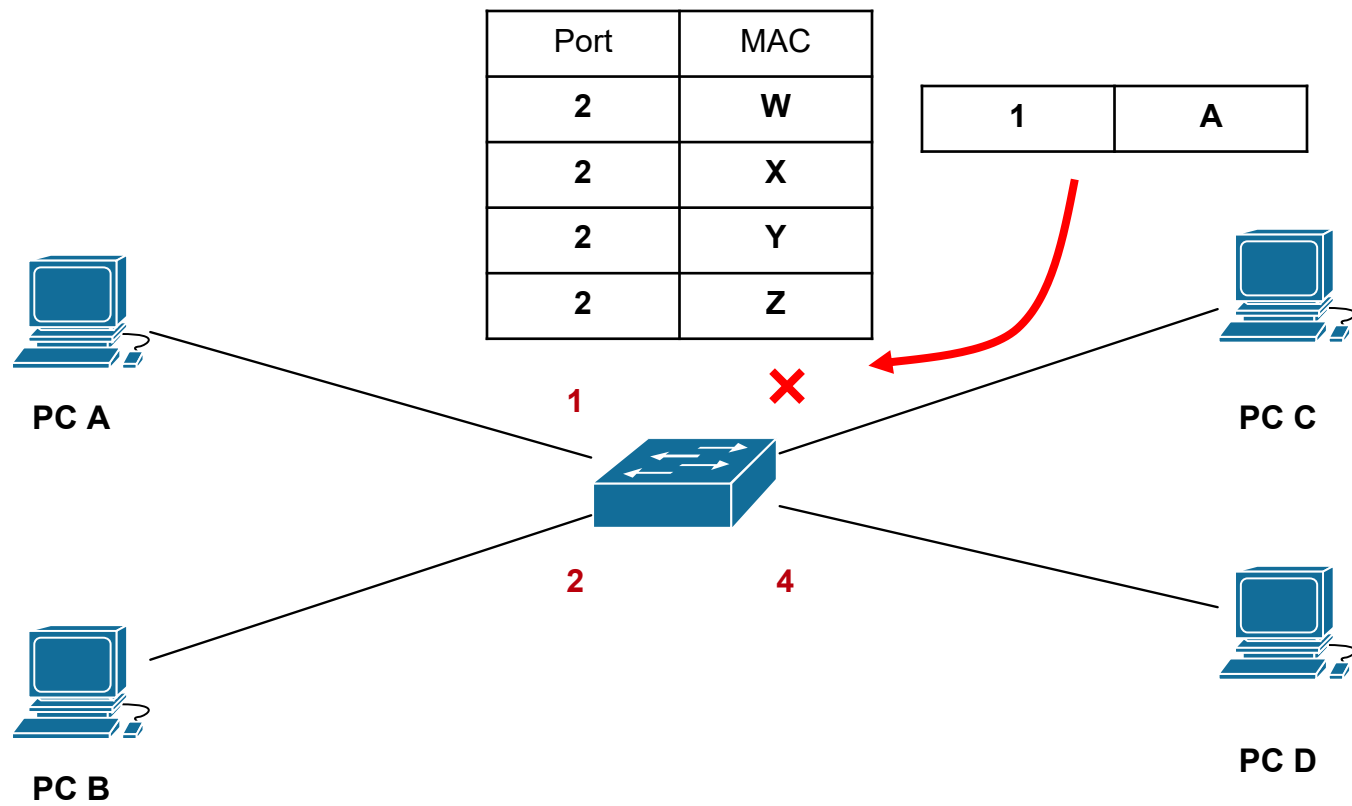


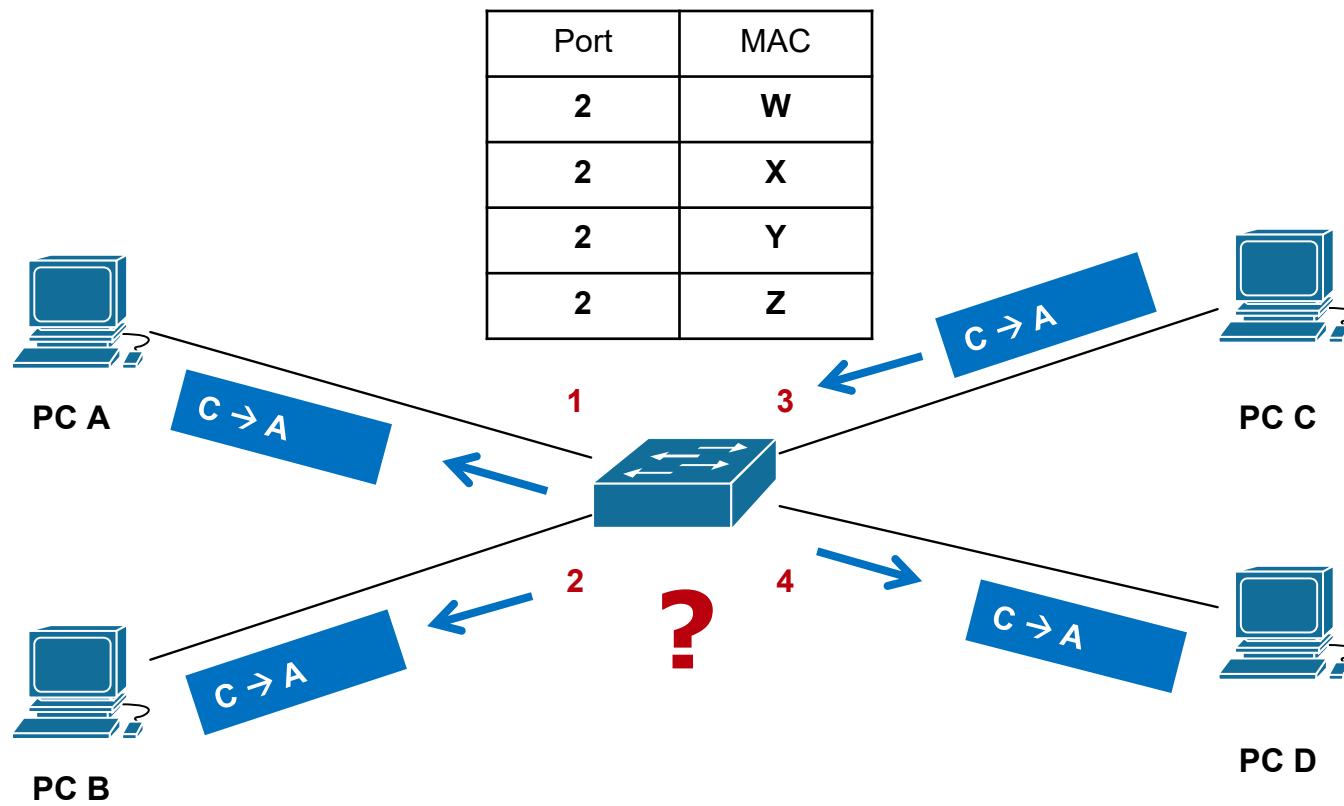












- Apart from MAC, it stores VLAN identifier for target port and timeout (Cisco default timeout is 300 seconds)
- **CAM records CANNOT be pushed out!!!**

Platform	CAM Size
Cisco Catalyst 2950	8 000
Cisco Catalyst 3560	12 000
Cisco Catalyst 3750	12 000
Linksys SRW224	4 000
Module to Cisco Catalyst 6500	128 000
HP ProCurve 2610	8 000
HP ProCurve 1400	8 000
Juniper EX3400	32,000
Cisco Catalyst 5000 Series	16,000

- Attack works only for limited amount of time (until CAM record timeout)
- When attacking, it is useful to generate twice more pseudo random MACs than it is CAM size
- Attack allows only sniffing
- Tools
 - Macof

```
root@ubuntu:~# macof -i eth0 -n 20000
c0:12:94:6d:2:34 17:84:37:5d:f7:f 0.0.0.0.17495 > 0.0.0.0.12933: S
321312800:321312800(0) win 512
```

CAM Overflow Countermeasure

PORT SECURITY

- Function allowing to define the maximum number of addresses on interface
 - Statically defined addresses are considered to be safe
 - Switch automatically adds any new unknown address to the CAM as dynamic or sticky record
 - IF a new record exceeds the MAC address limit THEN security violation is invoked

3w3d: %PORT_SECURITY-2-PSECURE_VIOLATION: Security violation occurred, caused by MAC address dea3.2764.5d22 on port FastEthernet0/2.

- Following three types of security violation are available
 - **Protect** = the frame with the wrong MAC is discarded
 - **Restrict** = the frame with the wrong MAC is discarded and incident is reported (console message, SMTP trap, Syslog)
 - **Shutdown** = the interface is shutdown and turned into err-disabled state

1) Enable port security:

```
Switch(config-if) # switchport port-security
```

2) Set a maximum number of MAC addresses that will be allowed on this port. The default is one:

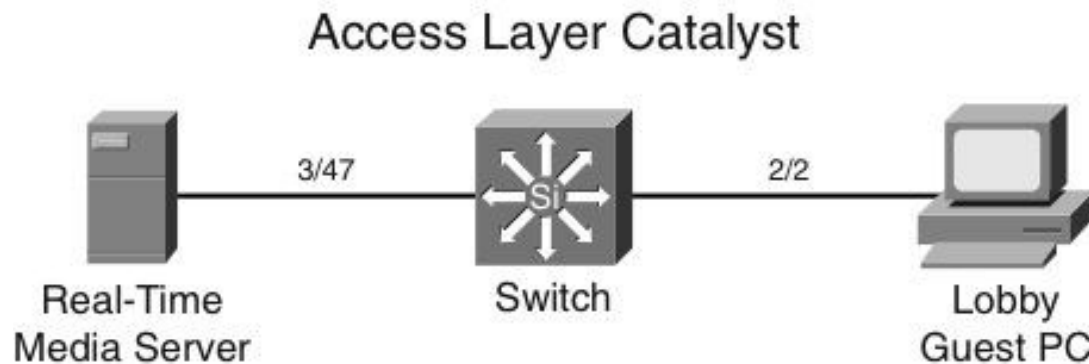
```
Switch(config-if) # switchport port-security maximum value
```

3) Specify which MAC addresses will be allowed on this port:

```
Switch(config-if) #  
switchport port-secur mac-address {mac-address|sticky}
```

4) Define what action an interface will take if a non-allowed MAC address attempts access:

```
Switch(config-if) # switchport port-security violation  
{shutdown | restrict | protect}
```

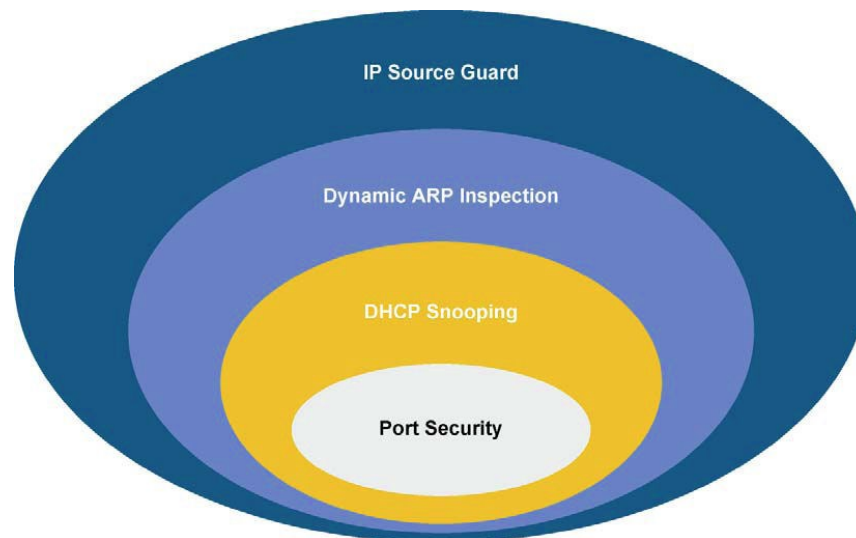


```

Switch(config)# interface FastEthernet 3/47
Switch(config-if)# switchport mode access
Switch(config-if)# switchport port-security
Switch(config-if)# switchport port-security mac-address 0000.0000.0008
Switch(config-if)# switchport port-security maximum 1
Switch(config-if)# switchport port-security aging time 2
Switch(config-if)# switchport port-security aging static
Switch(config-if)# switchport port-security violation restrict
Switch(config)# interface FastEthernet 2/2
Switch(config-if)# switchport mode access
Switch(config-if)# switchport port-security
Switch(config-if)# switchport port-security mac-address sticky
Switch(config-if)# switchport port-security maximum 1
Switch(config-if)# switchport port-security aging time 2
Switch(config-if)# switchport port-security aging static
Switch(config-if)# switchport port-security violation shutdown
  
```

IDENTITY SPOOFING

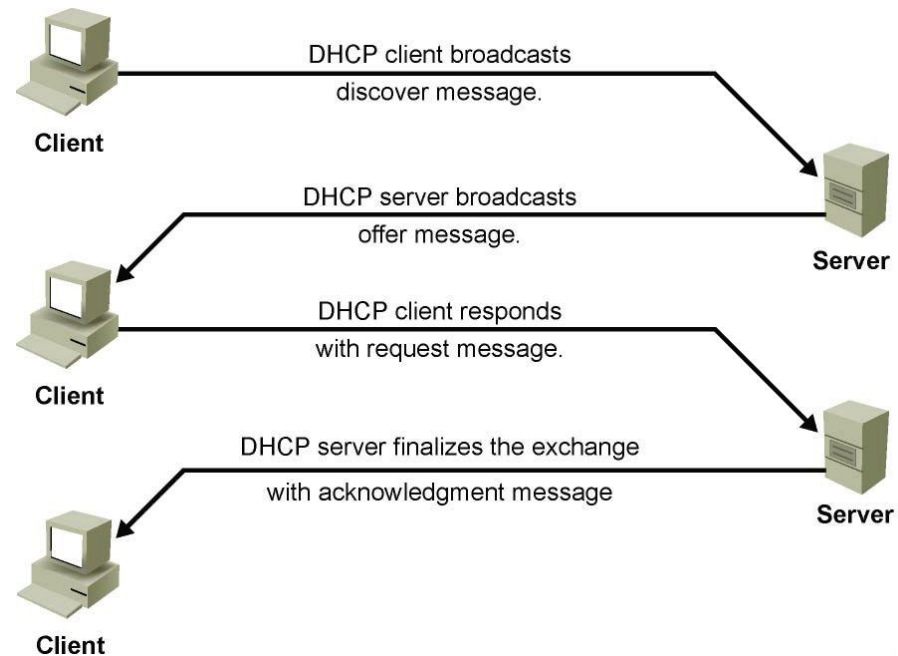
- **Spoofting** is attempt to fake device's identity
- Three types do exist according to used protocol
 - DHCP Spoofting
 - ARP Spoofting
 - IP Spoofting
- Catalyst switches contain several counter-measures

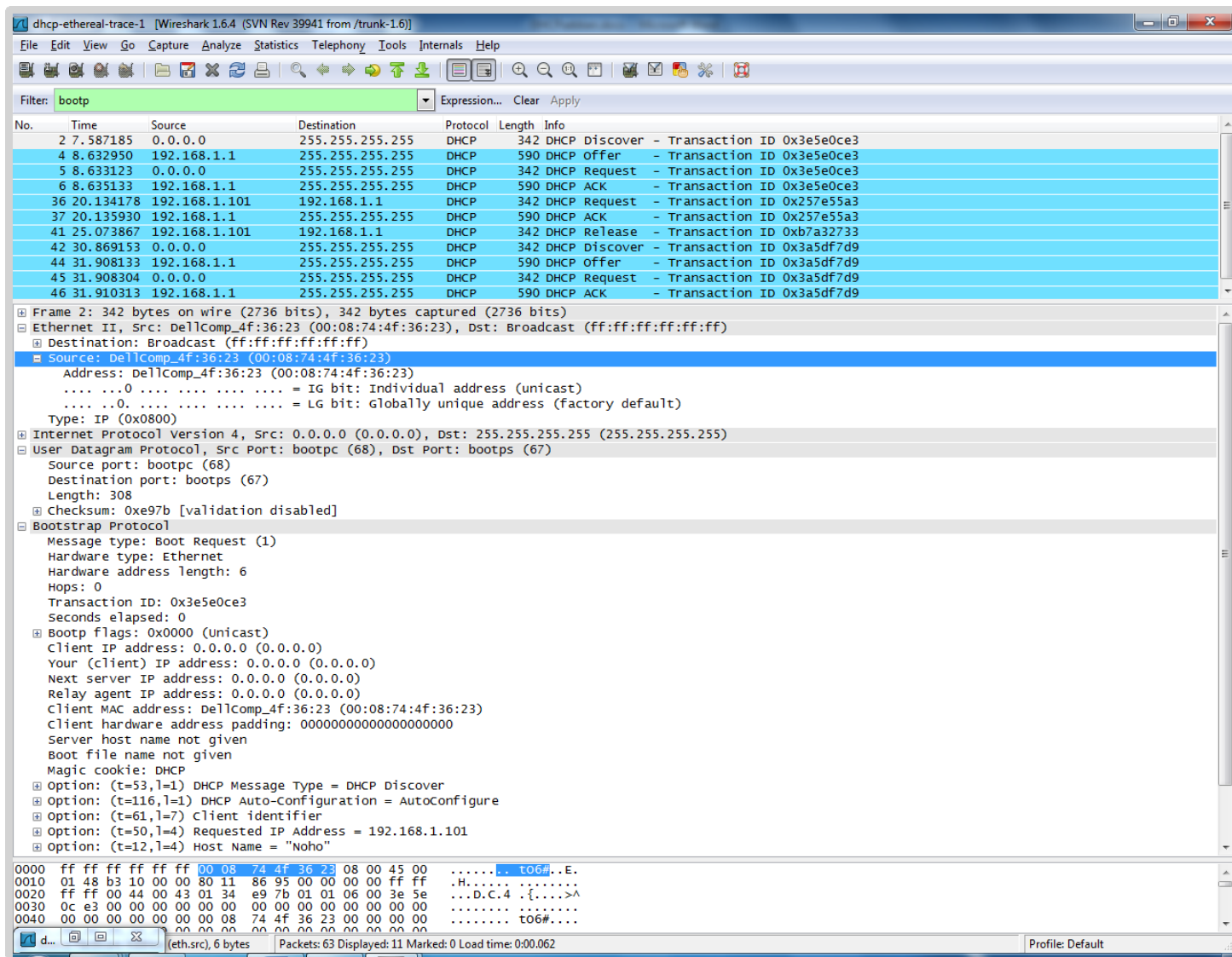


Attacks

DHCP SPOOFING

- DHCP is a client-server protocol that automatically assigns IP addresses and other network configuration parameters to devices on a network.
 - It ensures efficient use of IP addresses by dynamically allocating them and returning them to the pool when devices disconnect
- The DHCP process involves four key steps: Discovery, Offer, Request, and Acknowledgment
 - A client broadcasts a discovery message, receives an offer from the server, requests the offered IP, and then receives an acknowledgment with the assigned IP and other settings
- DHCP simplifies network management by automating IP address assignments, reducing the risk of IP conflicts, and allowing for centralized configuration updates.





dhcpc-ethereal-trace-1 [Wireshark 1.6.4 (SVN Rev 39941 from /trunk-1.6)]

File Edit View Go Capture Analyze Statistics Telephony Tools Internals Help

Filter: bootp Expression... Clear Apply

No.	Time	Source	Destination	Protocol	Length	Info
2	7.587185	0.0.0.0	255.255.255.255	DHCP	342	DHCP Discover - Transaction ID 0x3e5e0ce3
4	8.632950	192.168.1.1	255.255.255.255	DHCP	590	DHCP Offer - Transaction ID 0x3e5e0ce3
5	8.633123	0.0.0.0	255.255.255.255	DHCP	342	DHCP Request - Transaction ID 0x3e5e0ce3
6	8.635133	192.168.1.1	255.255.255.255	DHCP	590	DHCP ACK - Transaction ID 0x3e5e0ce3
36	20.134178	192.168.1.101	192.168.1.1	DHCP	342	DHCP Request - Transaction ID 0x257e55a3
37	20.135930	192.168.1.1	255.255.255.255	DHCP	590	DHCP ACK - Transaction ID 0x257e55a3
41	25.073867	192.168.1.101	192.168.1.1	DHCP	342	DHCP Release - Transaction ID 0xb7a32733
42	30.869153	0.0.0.0	255.255.255.255	DHCP	342	DHCP Discover - Transaction ID 0x3a5df7d9
44	31.908133	192.168.1.1	255.255.255.255	DHCP	590	DHCP Offer - Transaction ID 0x3a5df7d9
45	31.908304	0.0.0.0	255.255.255.255	DHCP	342	DHCP Request - Transaction ID 0x3a5df7d9
46	31.910313	192.168.1.1	255.255.255.255	DHCP	590	DHCP ACK - Transaction ID 0x3a5df7d9

Frame 2: 342 bytes on wire (2736 bits), 342 bytes captured (2736 bits)

- Ethernet II, Src: DellComp_4f:36:23 (00:08:74:4f:36:23), Dst: Broadcast (ff:ff:ff:ff:ff:ff)
 - Destination: Broadcast (ff:ff:ff:ff:ff:ff)
 - Source: DellComp_4f:36:23 (00:08:74:4f:36:23)
 - Address: DellComp_4f:36:23 (00:08:74:4f:36:23)
 -0..... = IG bit: Individual address (unicast)
 -0..... = LG bit: Globally unique address (factory default)
 - Type: IP (0x0800)
- Internet Protocol Version 4, Src: 0.0.0.0 (0.0.0.0), Dst: 255.255.255.255 (255.255.255.255)
- User Datagram Protocol, Src Port: bootpc (68), Dst Port: bootps (67)
 - Source port: bootpc (68)
 - Destination port: bootps (67)
 - Length: 308
 - Checksum: 0xe97b [validation disabled]
- Bootstrap Protocol
 - Message type: Boot Request (1)
 - Hardware type: Ethernet
 - Hardware address length: 6
 - Hops: 0
 - Transaction ID: 0x3e5e0ce3
 - Seconds elapsed: 0
 - Boot flags: 0x0000 (Unicast)
 - Client IP address: 0.0.0.0 (0.0.0.0)
 - Your (client) IP address: 0.0.0.0 (0.0.0.0)
 - Next server IP address: 0.0.0.0 (0.0.0.0)
 - Relay agent IP address: 0.0.0.0 (0.0.0.0)
 - Client MAC address: DellComp_4f:36:23 (00:08:74:4f:36:23)
 - Client hardware address padding: 00000000000000000000
 - Server host name not given
 - Boot file name not given
 - Magic cookie: DHCP
 - Option: (t=53,l=1) DHCP Message Type = DHCP Discover
 - Option: (t=116,l=1) DHCP Auto-Configuration = AutoConfigure
 - Option: (t=61,l=7) Client identifier
 - Option: (t=50,l=4) Requested IP Address = 192.168.1.101
 - Option: (t=12,l=4) Host Name = "Noho"

```

0000  ff ff ff ff ff ff 00 08 74 4f 36 23 08 00 45 00  .....t06...E.
0010  01 48 b3 10 00 00 80 11 86 95 00 00 00 00 ff ff  .H.....^
0020  ff ff 00 44 00 43 01 34 e9 7b 01 01 06 00 3e 5e  .D.C.4.....>
0030  0c e3 00 00 00 00 00 00 00 00 00 00 00 00 00 00  .....t06#...
0040  00 00 00 00 00 00 00 00 74 4f 36 23 00 00 00 00  .....t06#...
    
```

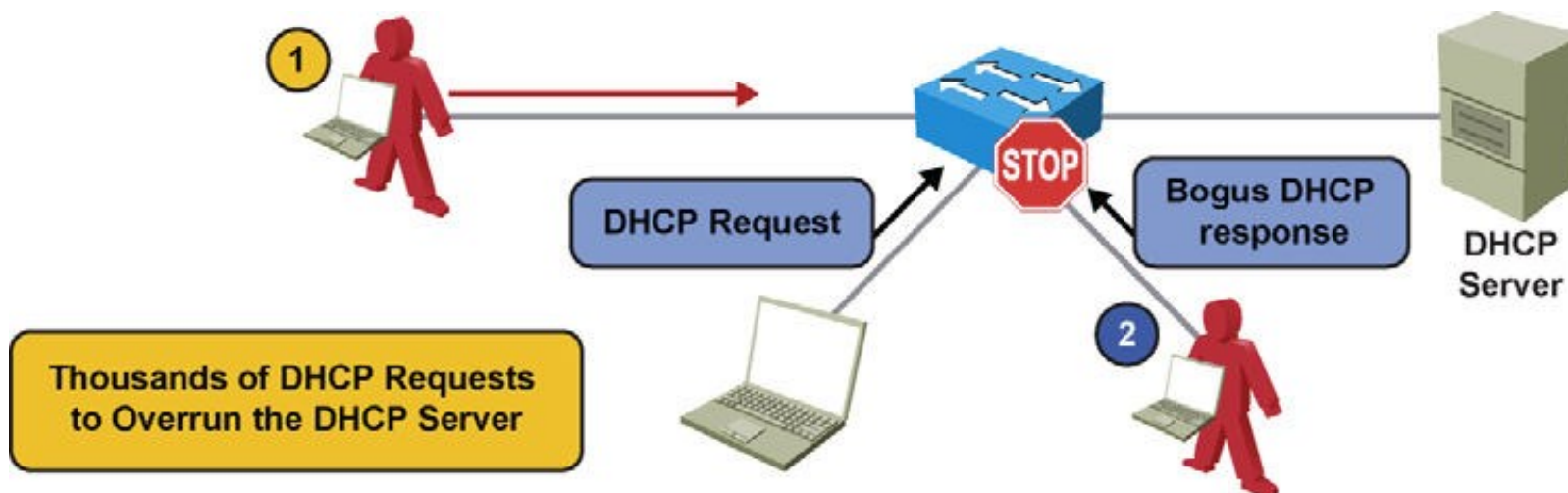
d... (eth.src), 6 bytes Packets: 63 Displayed: 11 Marked: 0 Load time: 0:00.062 Profile: Default

- **Scenario 1**

- An attacker launches a DoS attack by sending thousands of DHCP requests
- The DHCP server does not have the capability to determine whether the request is genuine and therefore might end up exhausting all the available IP addresses
- This results in a legitimate client not getting a IP address via DHCP

- **Scenario 2**

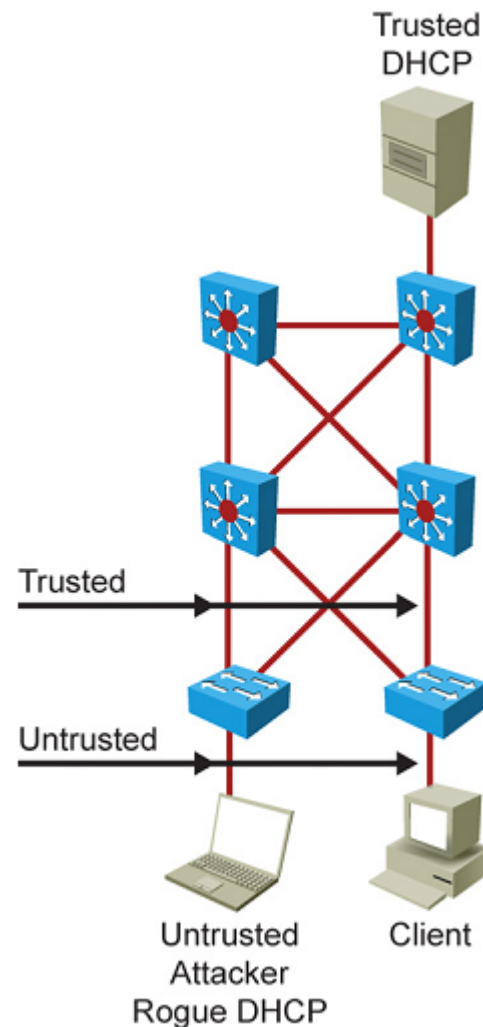
- Attacker attaches a DHCP server to the network and has it assume the role of the DHCP server for that segment
- This enables the intruder to give out false DHCP information for the default gateway and domain name servers, which points clients to the hacker's machine



Countermeasure against DHCP Spoofing

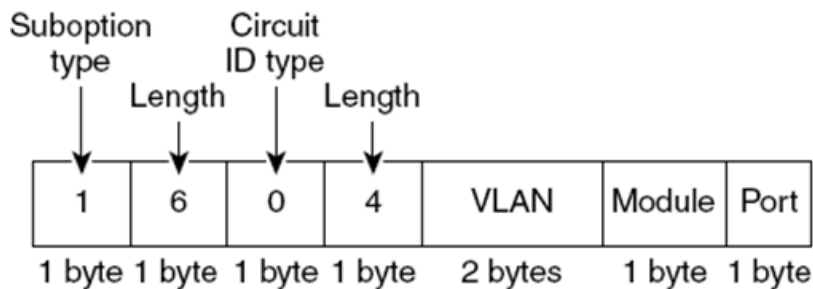
DHCP SNOOPING

- **DHCP Snooping** prevents client attacks on the DHCP server and switch
 - DHCP requests (discover) and responses (offer) are tracked
 - Rate-limiting requests on untrusted interfaces limit DoS attacks on DHCP server (transition to err-disabled state)
 - Deny responses on untrusted interfaces in order to stop malicious or errant DHCP servers
- Ports differentiation
 - On untrusted ports are connected end-stations
 - On trusted ports or behind them are DHCP servers
 - Default port type is untrusted
- **DHCP Snooping Database**
 - Source MAC, leased IP address, lease time, VLAN and interface
 - It is used also by DAI and IPSG

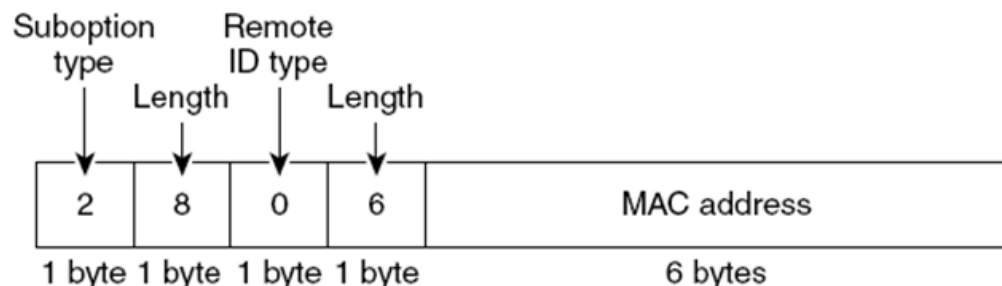


- IF DHCP Snooping intercepts request
THEN it inserts Option-82 into the message
- **Option-82** is two parts information field containing switch and its interface on which request was received
 - Circuit ID identifies clients interface
 - Remote ID identifies switch to which client is attached

Circuit ID Suboption Frame Format



Remote ID Suboption Frame Format



- DHCP Snooping discards...
 - server DHCP messages (Offer, Ack, Nak, Leasequery) received on untrusted port
 - client DHCP messages (Discover, Request) containing different chaddr MAC address than what is source MAC of sender
 - client DHCP Release and Decline messages with MAC addresses that are present on different interface in DHCP Snooping Database
 - all messages received on untrusted port containing different relay agent address than 0.0.0.0 or contains Option-82
- DHCP Snooping forwards...
 - client DHCP messages only to trusted ports
 - server DHCP messages to recipient based on Option-82 information (even thou they are broadcasts or are intended to unknown receiver)

1) Enable DHCP globally

```
Switch(config)# ip dhcp snooping
```

2) Enable DHCP Option 82

```
Switch(config)# ip dhcp snooping information option
```

3) Configure DHCP server interfaces or uplink ports as trusted

```
Switch(config-if)# ip dhcp snooping trust
```

4) Configure the number of DHCP packets per second (pps)

```
Switch(config-if)# ip dhcp snooping limit rate rate
```

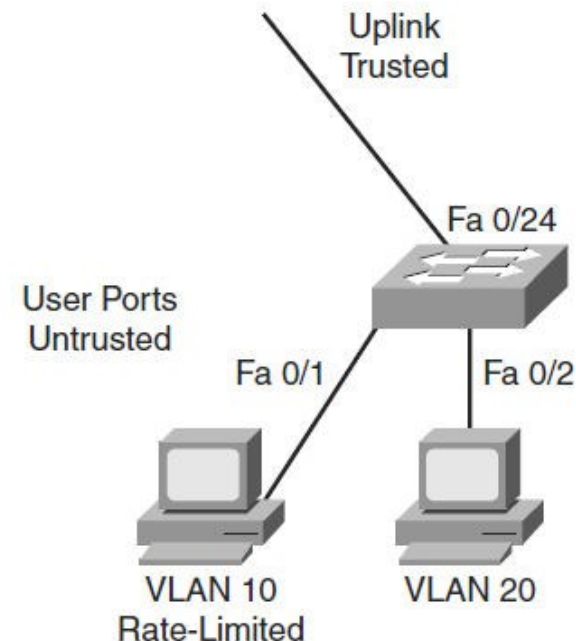
5) Enable DHCP snooping on specific VLANs

```
Switch(config)# ip dhcp snooping vlan number [number]
```

6) Verify the configuration

```
Switch# show ip dhcp snooping
```

```
switch(config)# ip dhcp snooping
switch(config)# ip dhcp snooping information option
switch(config)# ip dhcp snooping vlan 10,20
switch(config)# interface fastethernet 0/1
switch(config-if)# description Access Port
switch(config-if)# ip dhcp limit rate 5
switch(config)# interface fastethernet 0/24
switch(config-if)# description Uplink
switch(config-if)# switchport mode trunk
switch(config-if)# switchport trunk allowed vlan 10,20
switch(config-if)# ip dhcp snooping trust
```



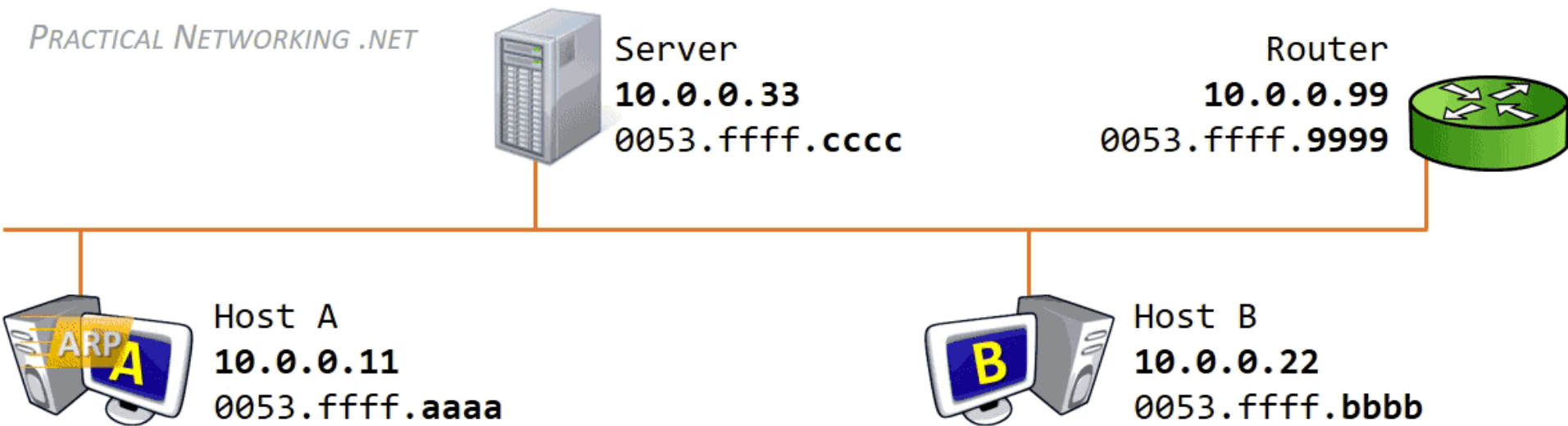


Attack

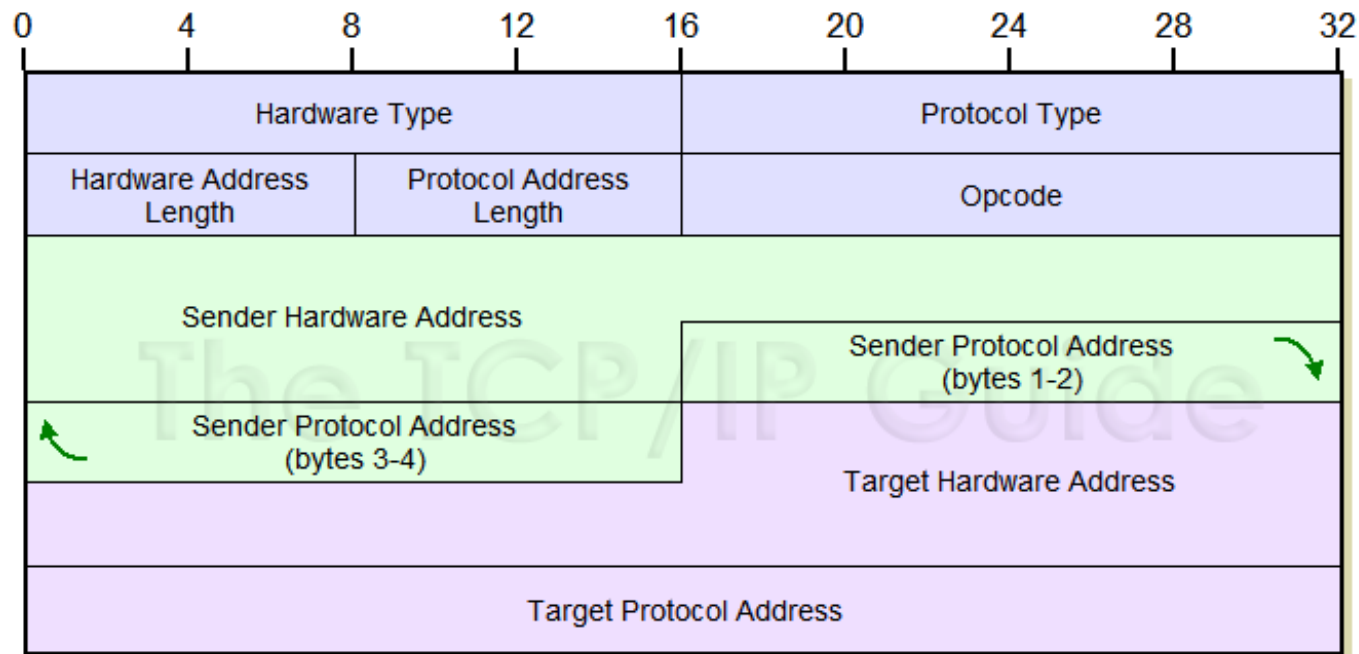
ARP MITM / SPOOFING

- ARP is glue between L3 IP address and its corresponding L2 MAC address

PRACTICAL NETWORKING .NET

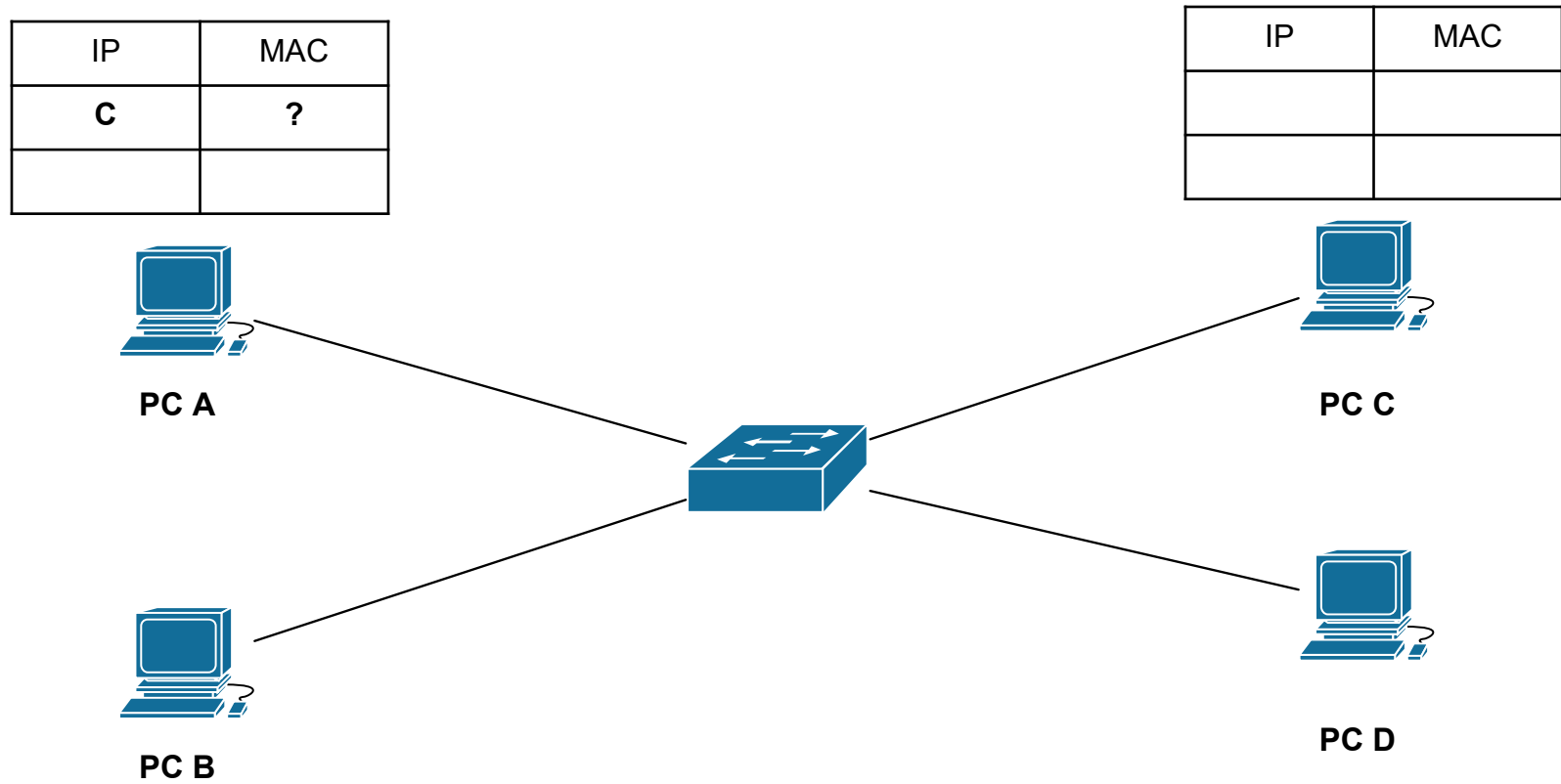


- ARP Spoofing sends unsolicited so called gratuitous ARP response message in order to map different MAC address to a given IP address
- Two possible outcomes
 - Denial of Service by mapping non-existing MAC to IP
 - Man-in-the-Middle by mapping attackers MAC to IP
- Tools
 - Arpspoof
 - Ettercap
 - Cain & Abel



▼ Address Resolution Protocol (request)

- Hardware type: Ethernet (1)
- Protocol type: IPv4 (0x0800)
- Hardware size: 6
- Protocol size: 4
- Opcode: request (1)
- Sender MAC address: 00:53:ff:ff:aa:aa
- Sender IP address: 10.0.0.11
- Target MAC address: 00:00:00:00:00:00
- Target IP address: 10.0.0.22



IP	MAC
C	?

Sender HW address:

A

Sender proto address:

A

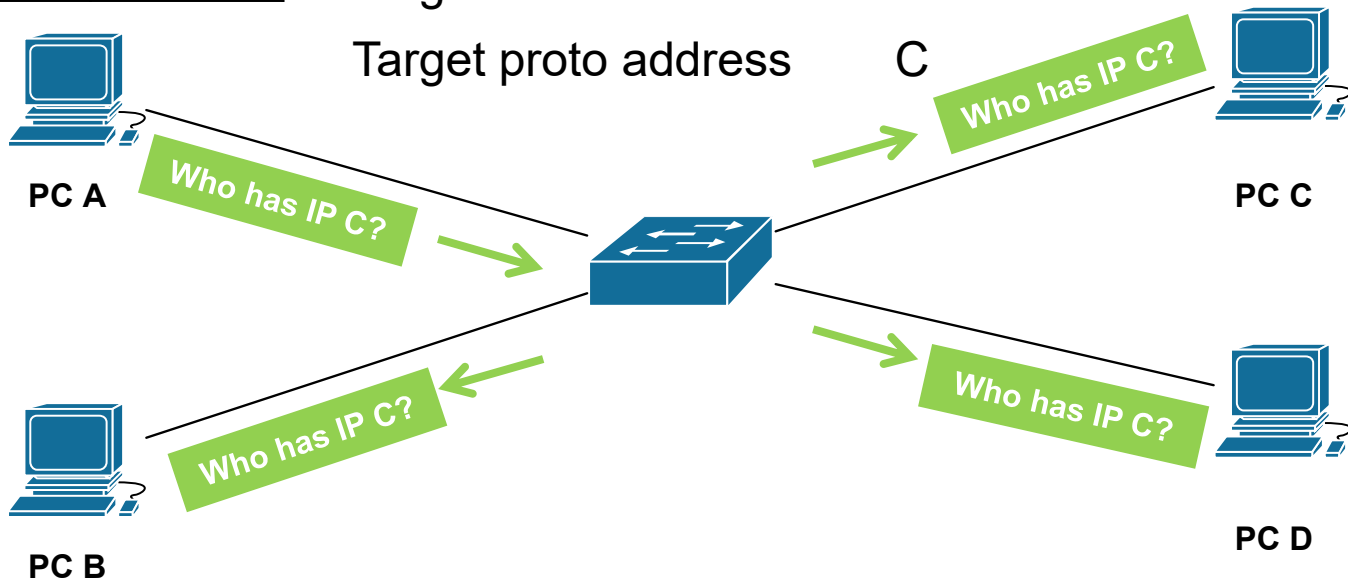
Target HW address:

none

Target proto address

C

IP	MAC



IP	MAC
C	?



PC A



PC B

Sender HW address: A
Sender proto address: A
Target HW address: none
Target proto address: C



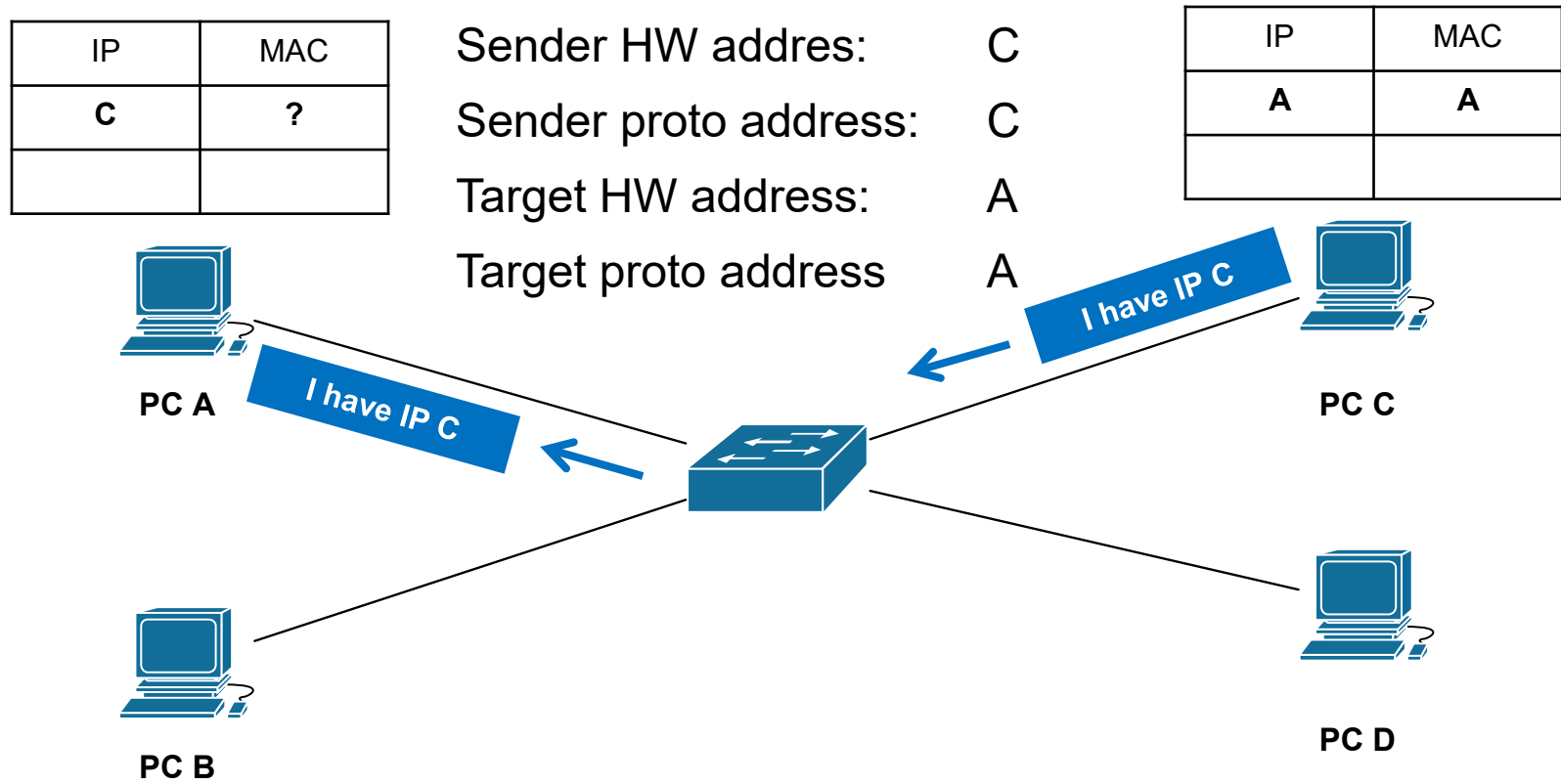
IP	MAC
A	A

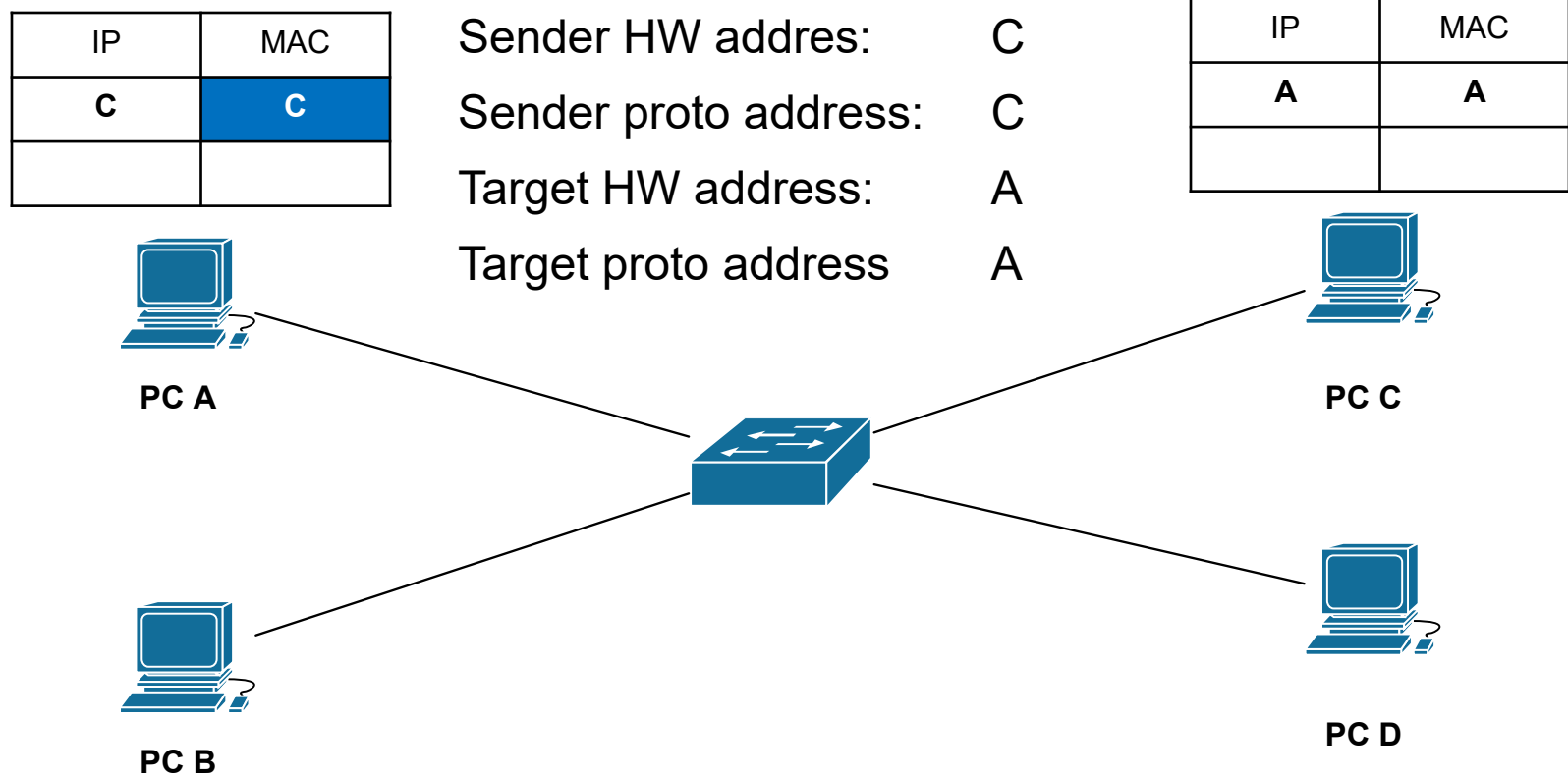


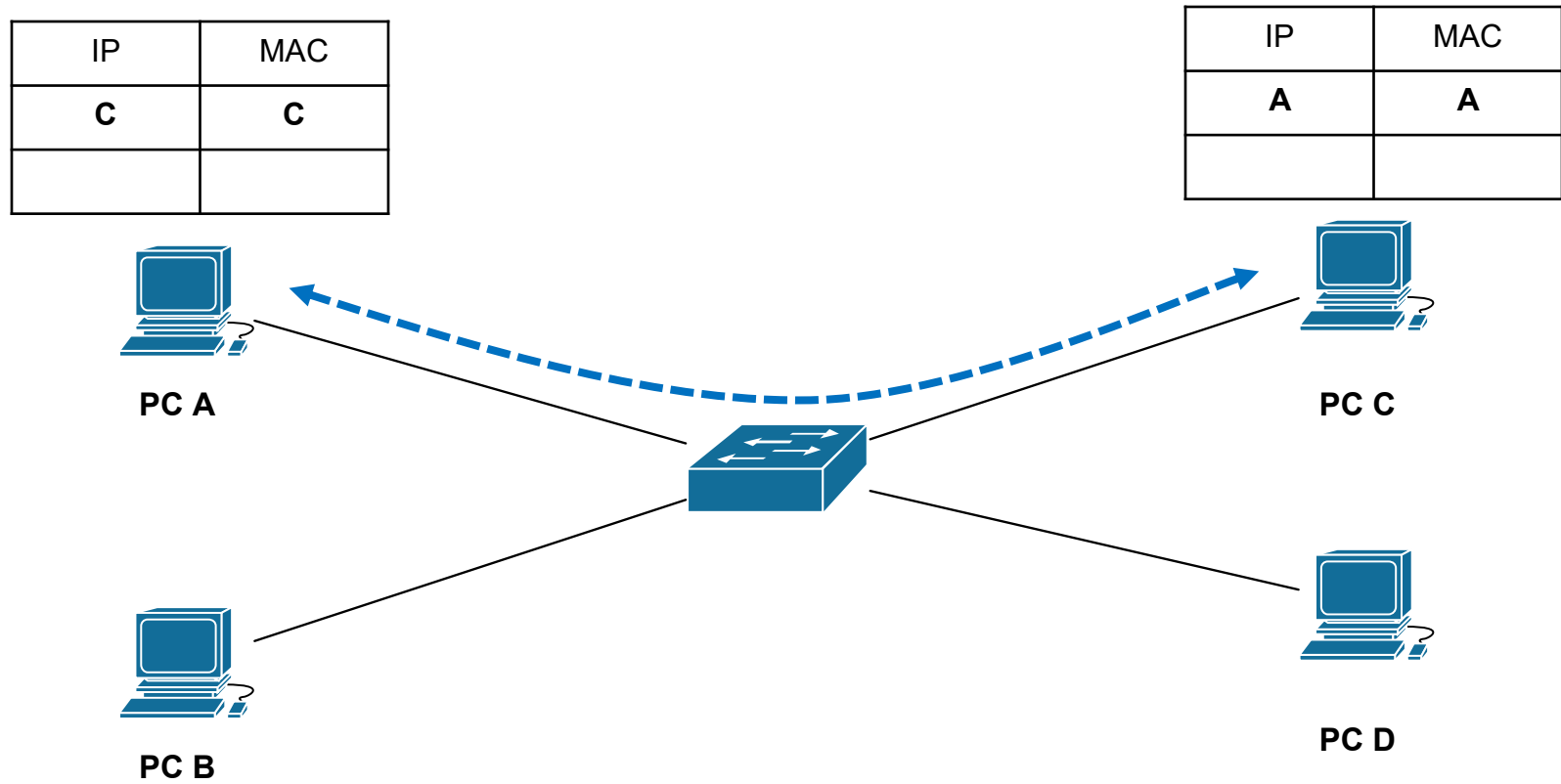
PC C

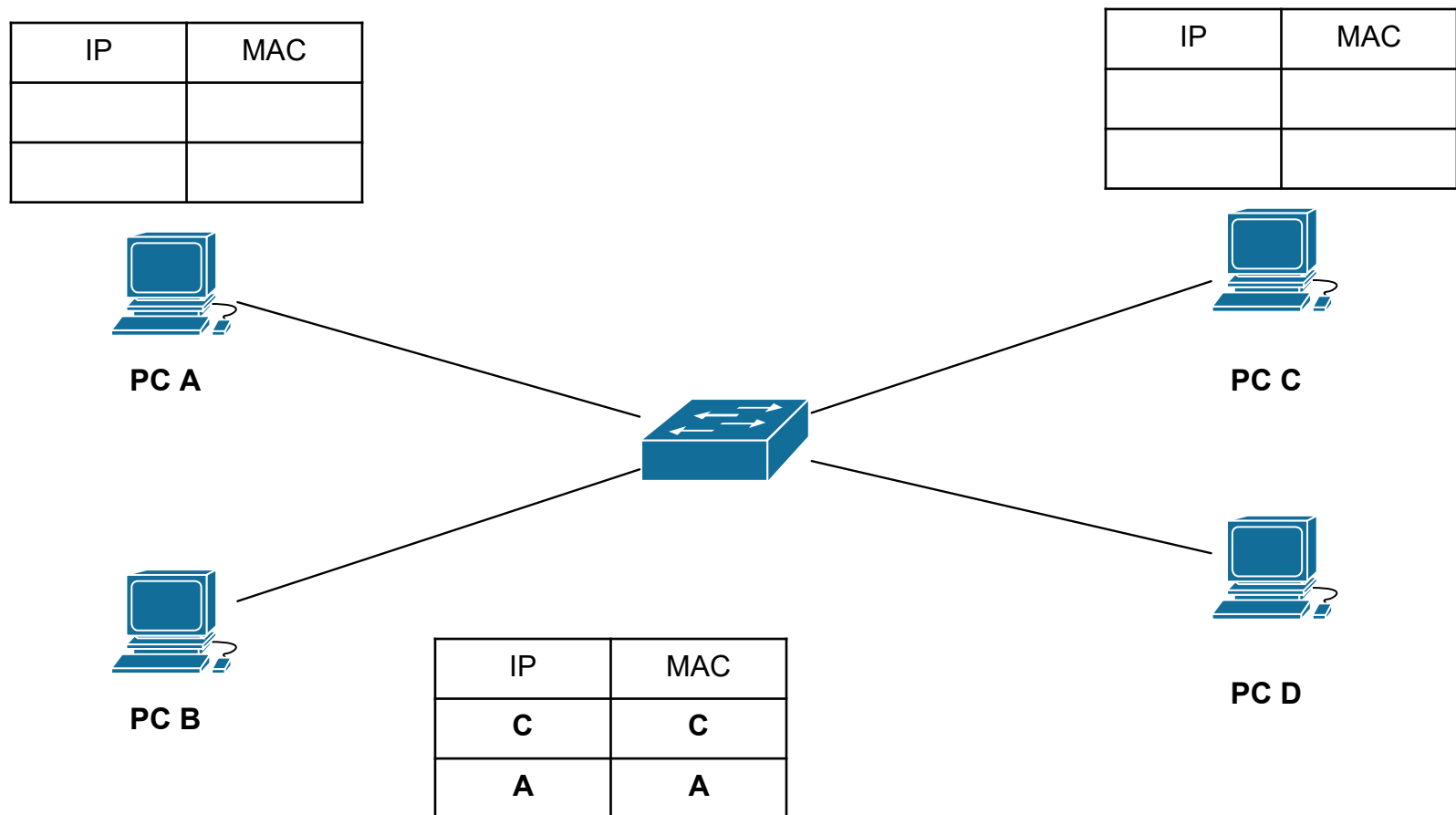


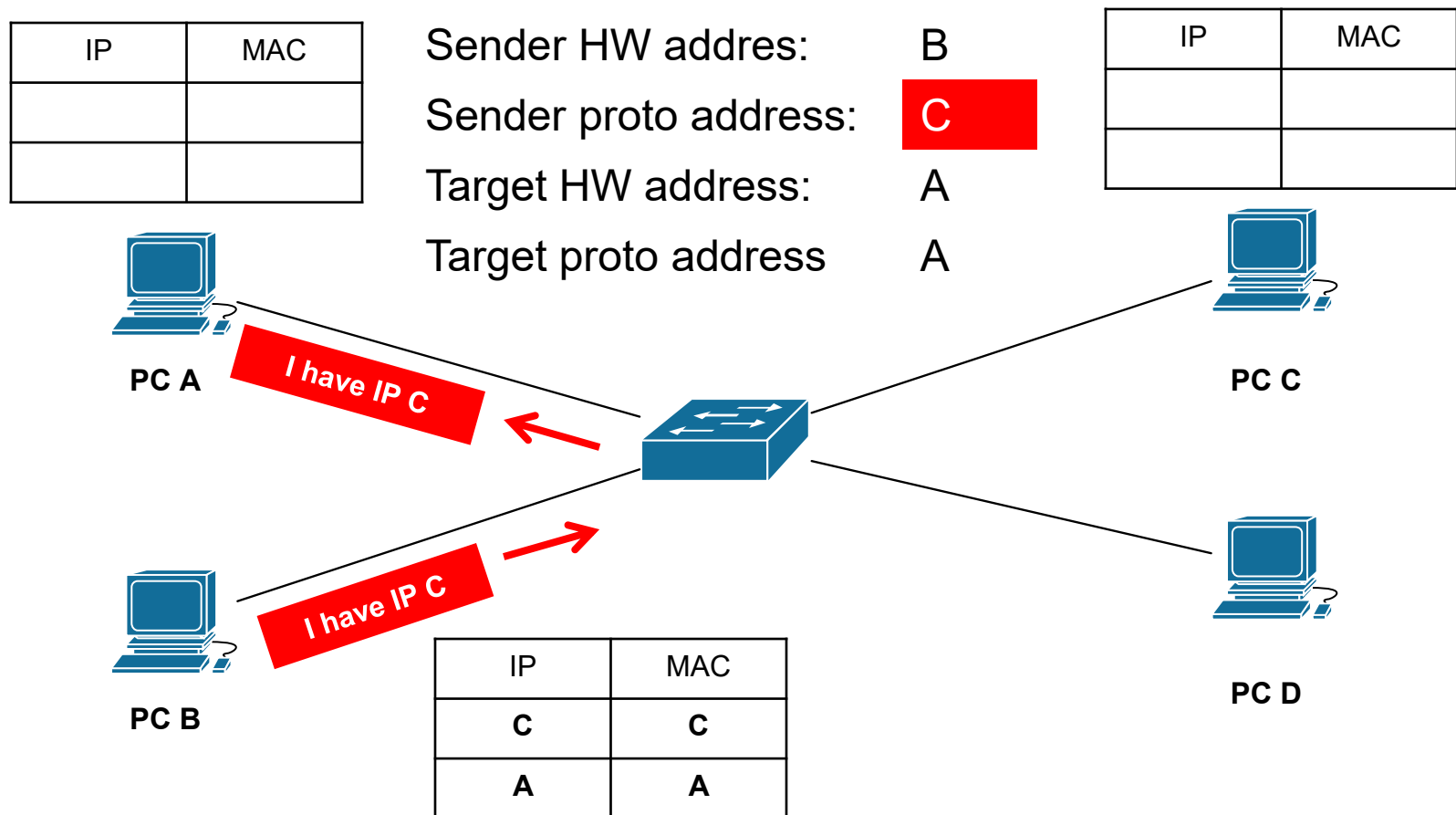
PC D

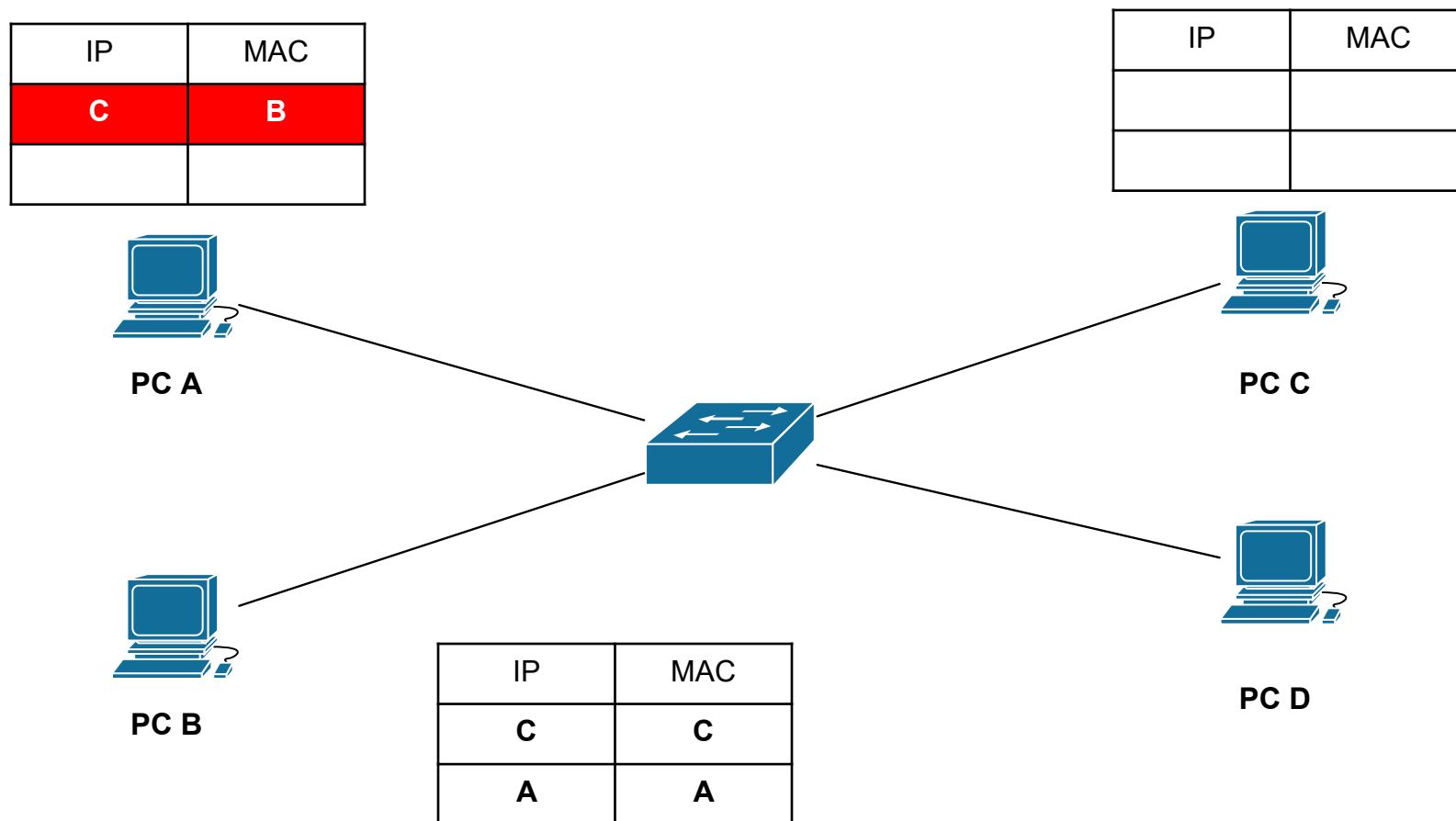


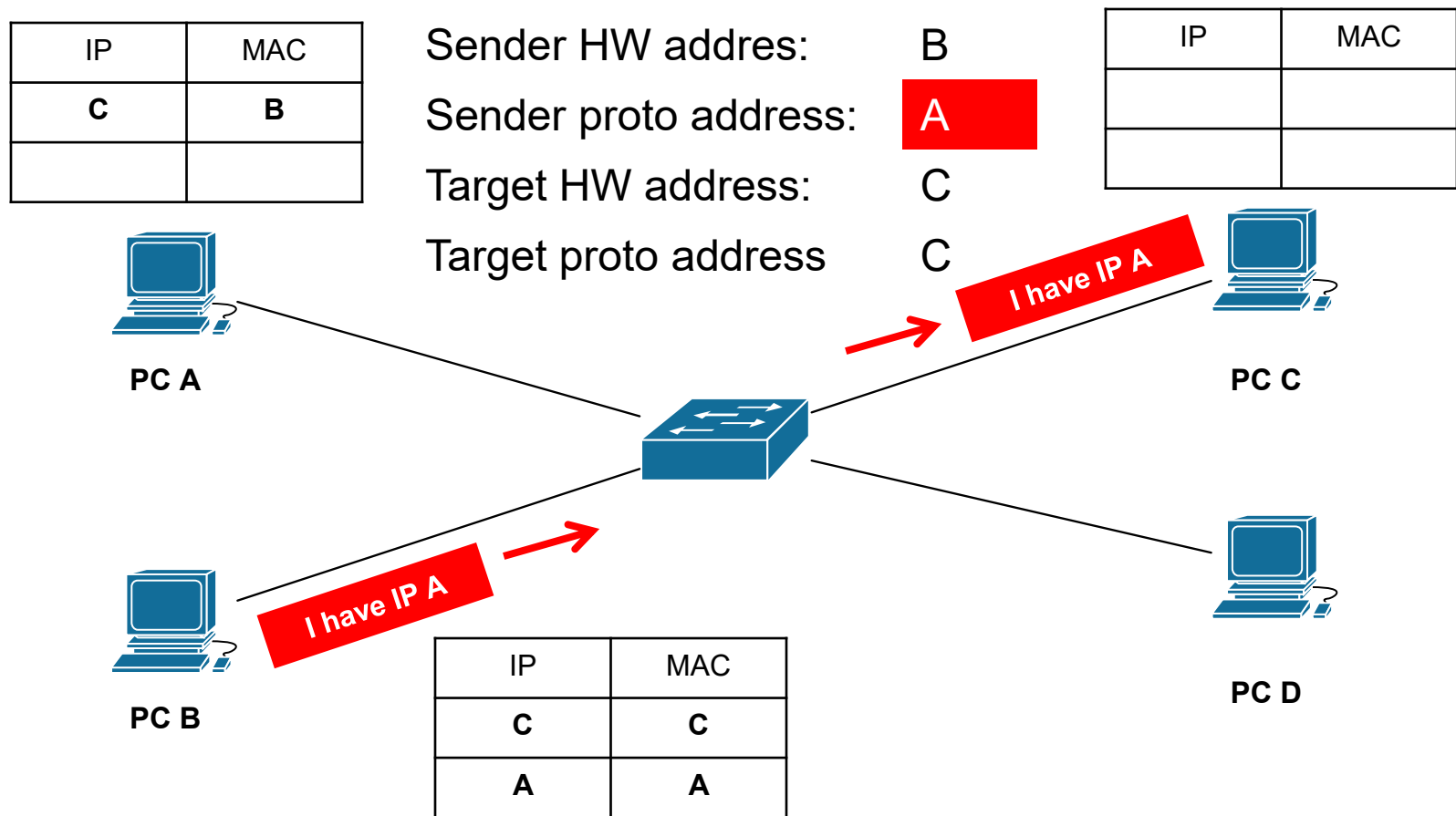


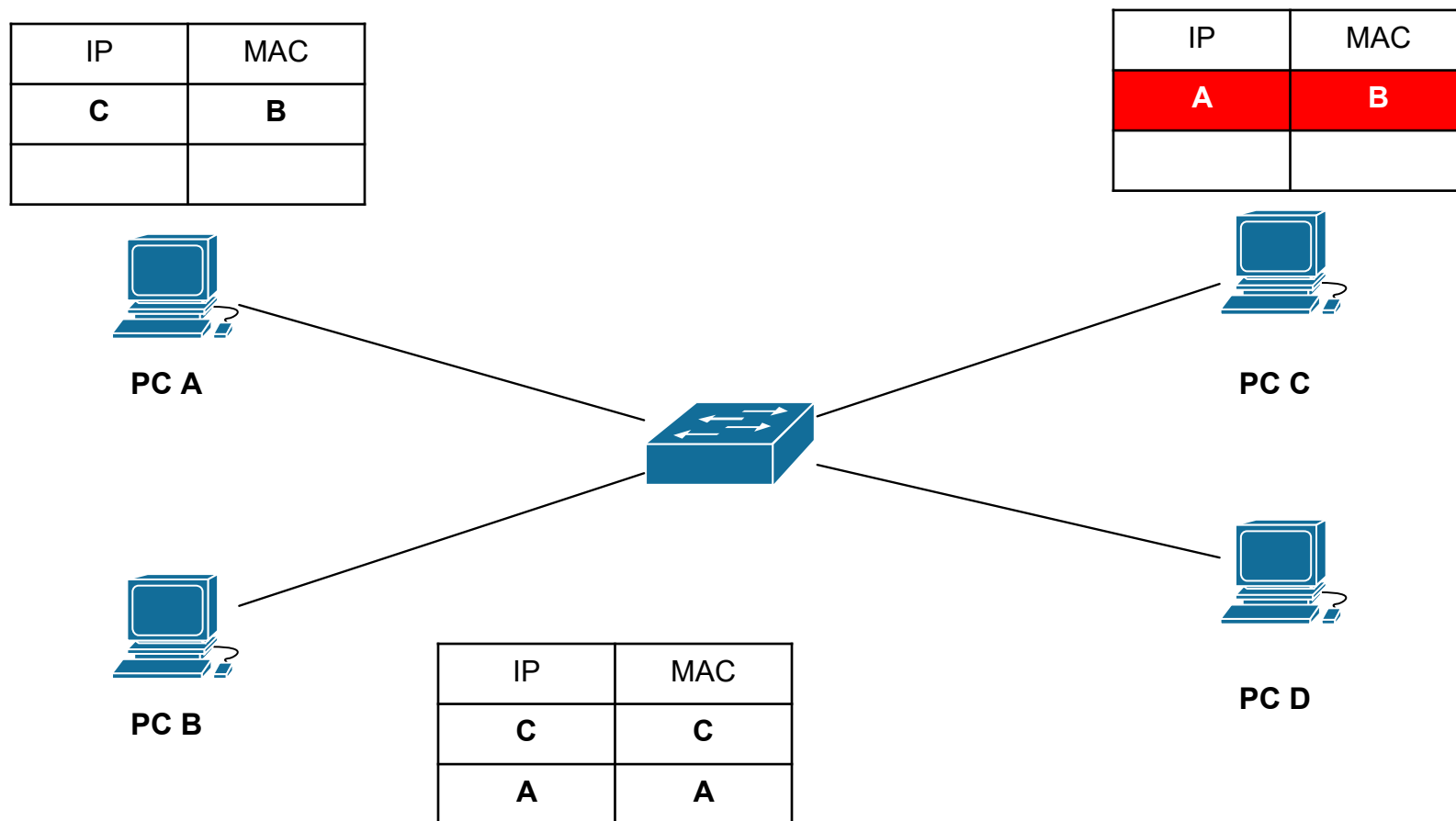


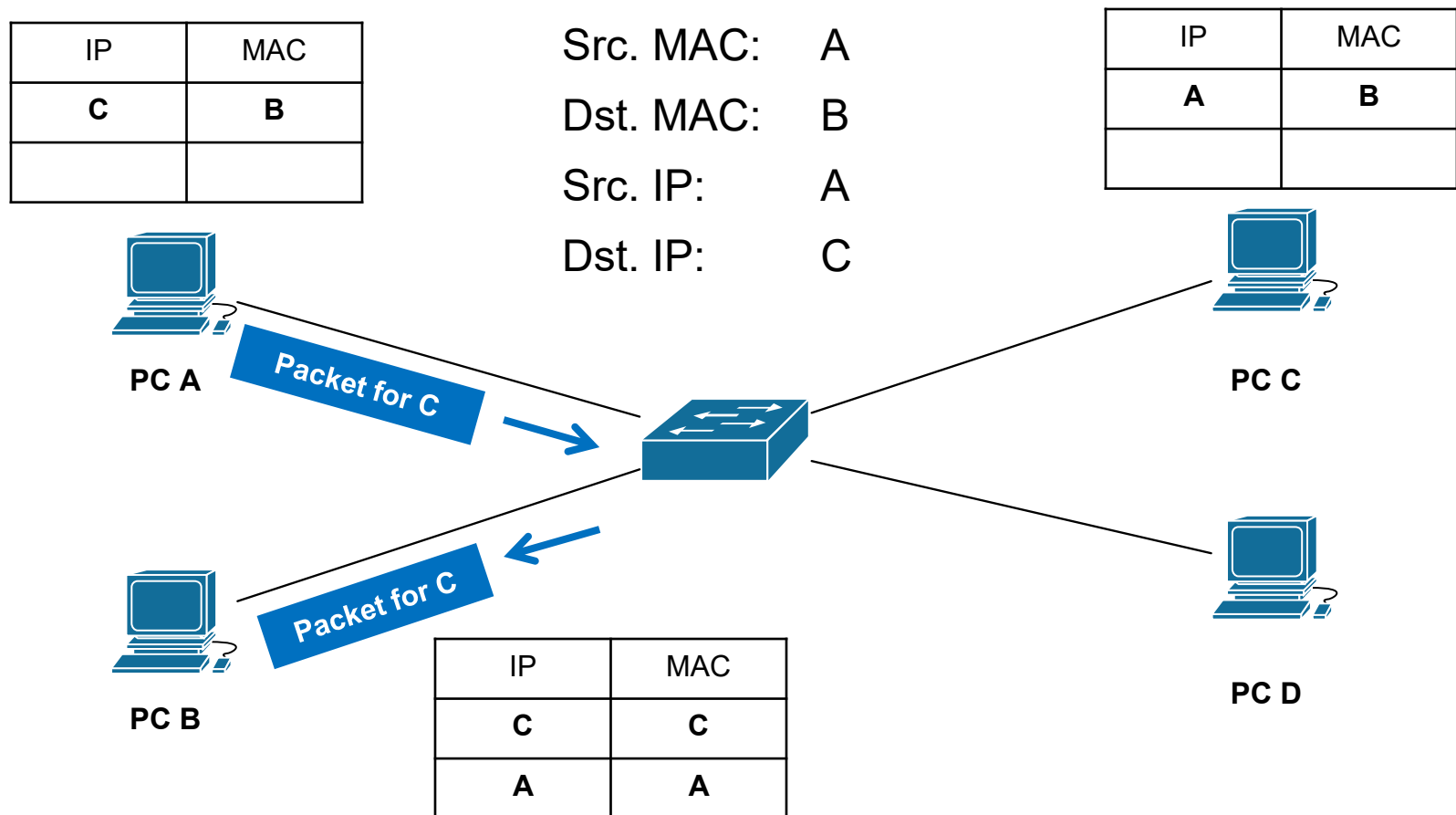


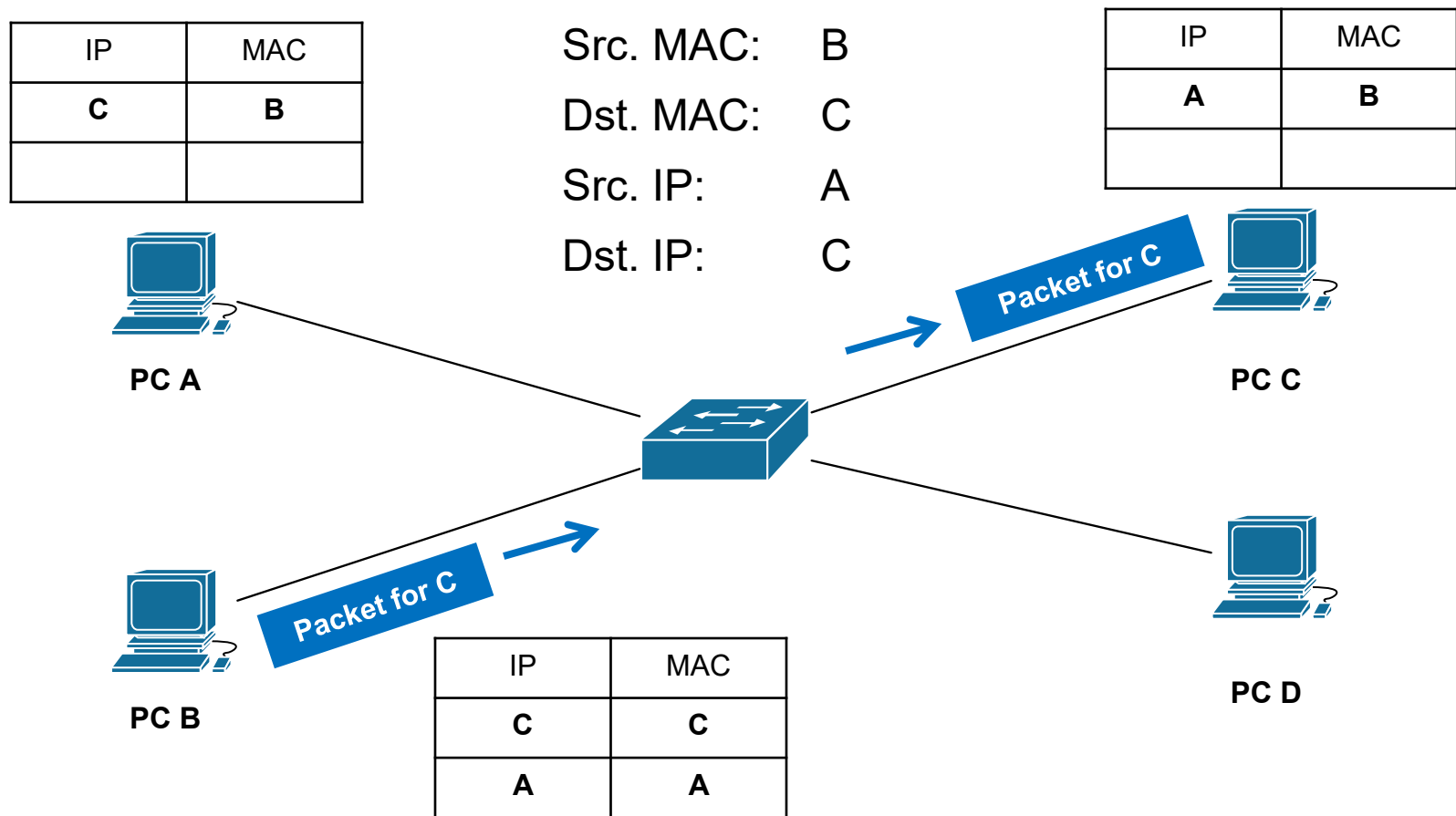


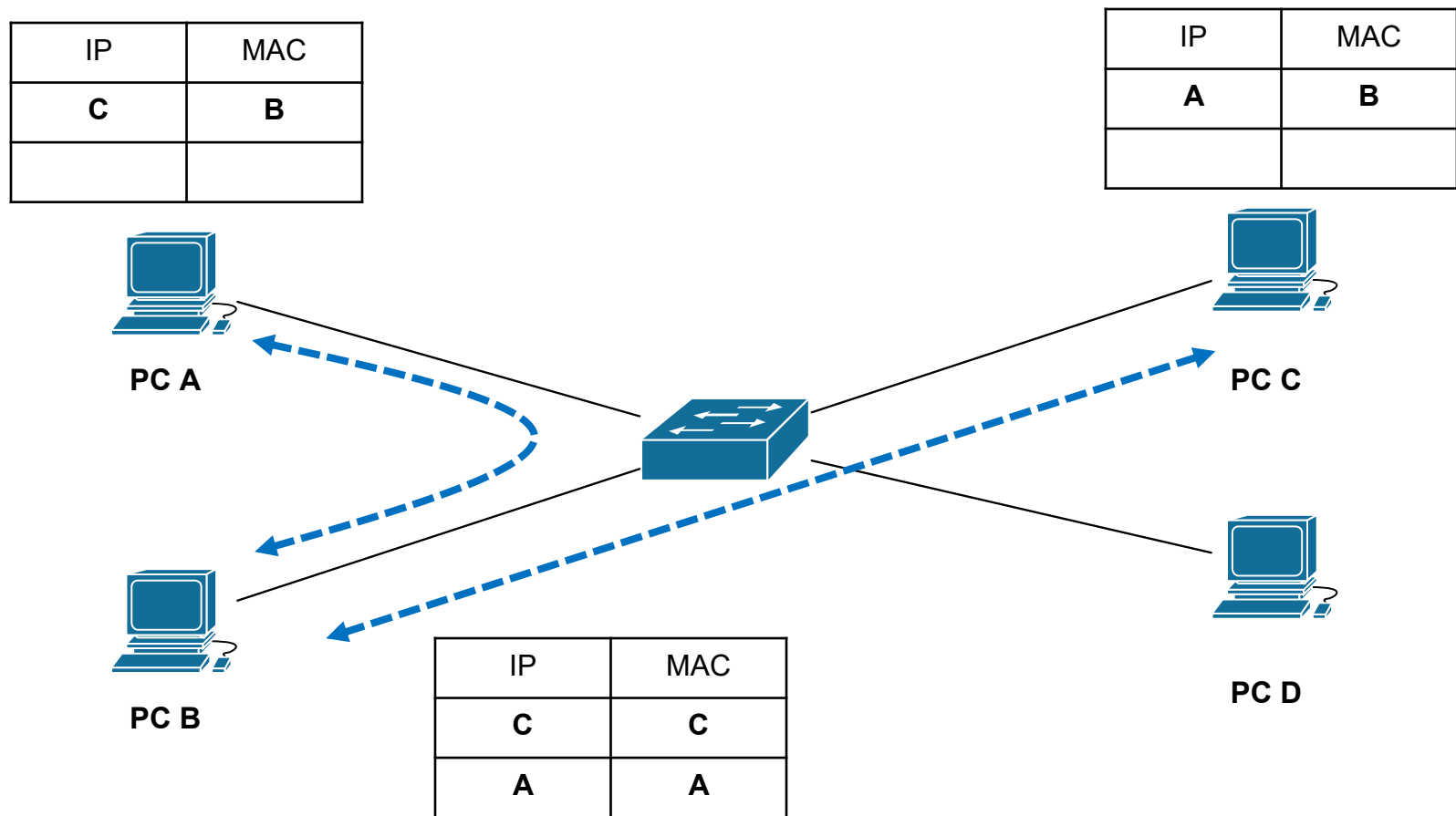












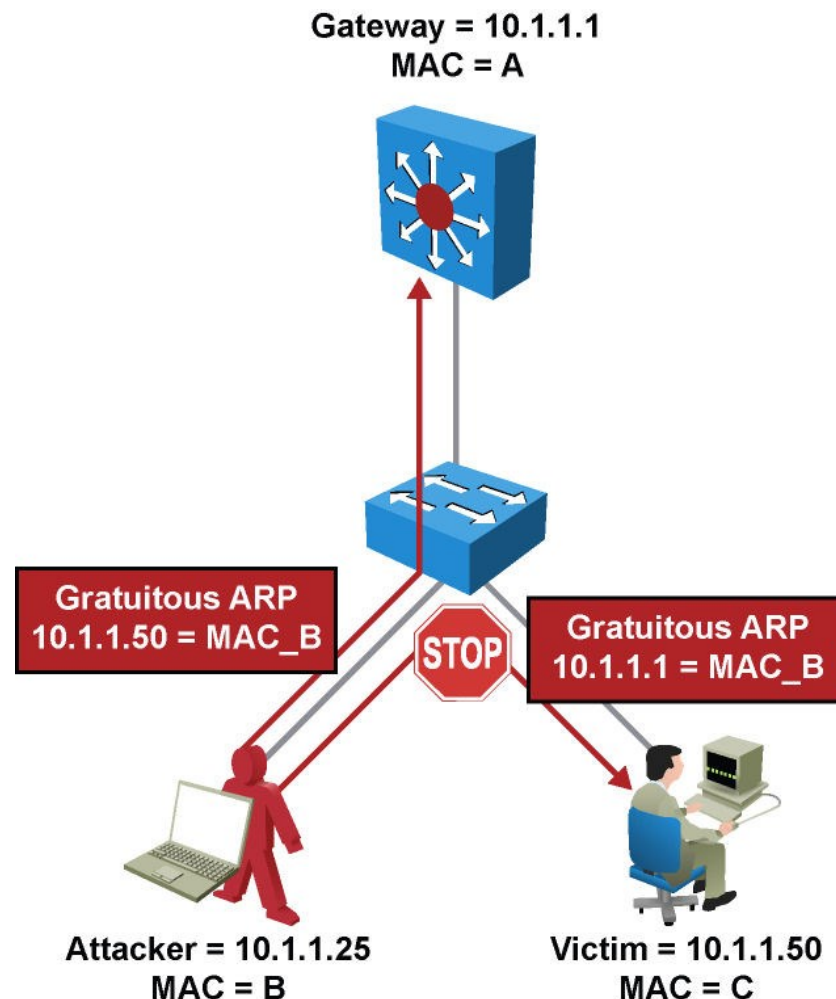
- Updated by ARP Response and ARP Request that should be answered
- Attack works only until timeout expires the record
- Each record has dynamic timeout

Operating System	Default Timeout
Windows 10/8/Vista	Random value between 15 and 45 seconds
Ubuntu/Linux	Typically 60 seconds, but can vary based on kernel settings
macOS Sierra	20 minutes for validated hosts
Cisco IOS 12.0	4 hours

Countermeasure against ARP MitM

DYNAMIC ARP INSPECTION

- **Dynamic ARP Inspection (DAI)** is precaution against ARP Spoofing attacks that uses DHCP Snooping Database to validate senders and receivers MAC and IP addresses
- Port types
 - Untrusted ports heading to end-devices
 - Trusted ports heading to other routers and switches
 - Default port type is untrusted
- DAI violation drops packet and logs incident
- DAI allows rate-limiting of ARP messages
 - By default it is set to 15 messages per second on untrusted ports



1) Enable DAI on a VLAN or range of VLANs

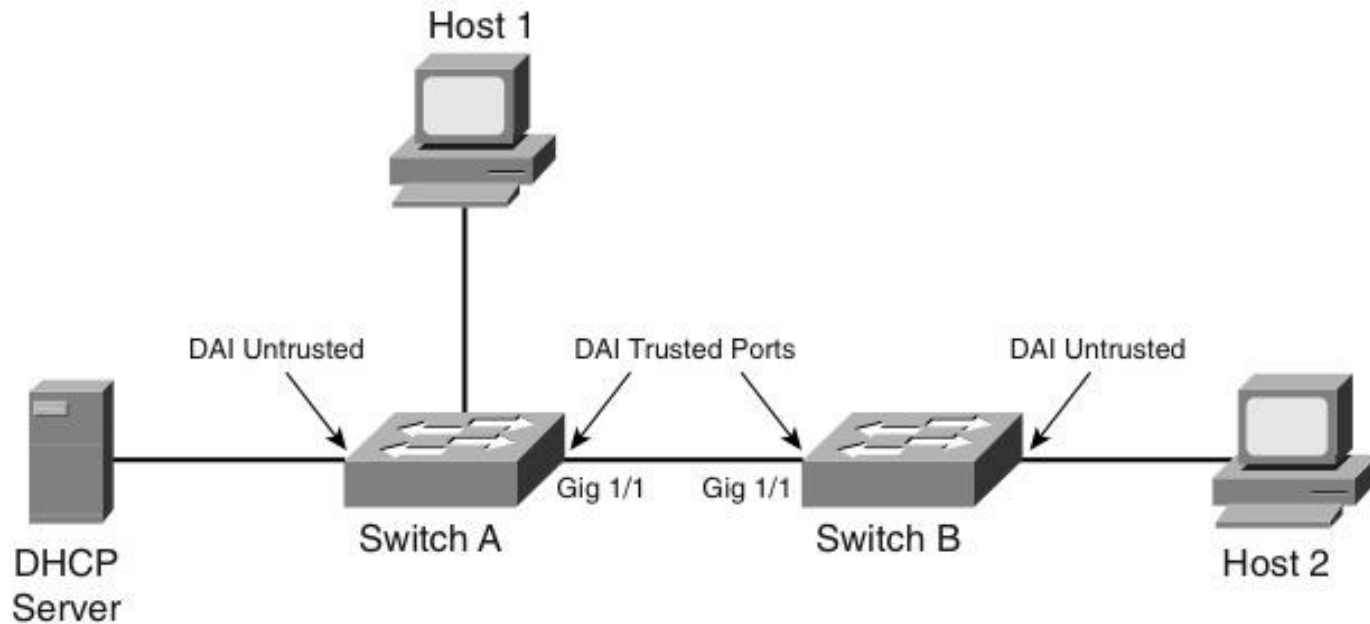
```
Switch(config)# ip arp inspection vlan vlan-range
```

2) Enable DAI on an interface and sets the interface as a trusted interface

```
Switch(config-if)# ip arp inspection trust
```

3) Optionally, additional checks for src/dst MACs, IP different than 0.0.0.0/255.255.255.255 or multicast

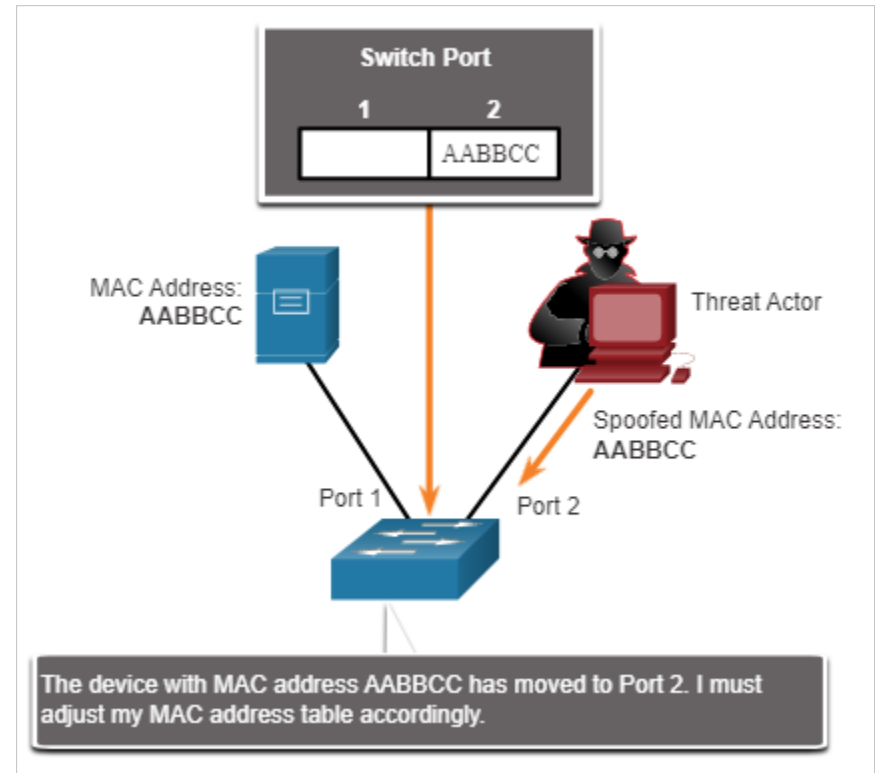
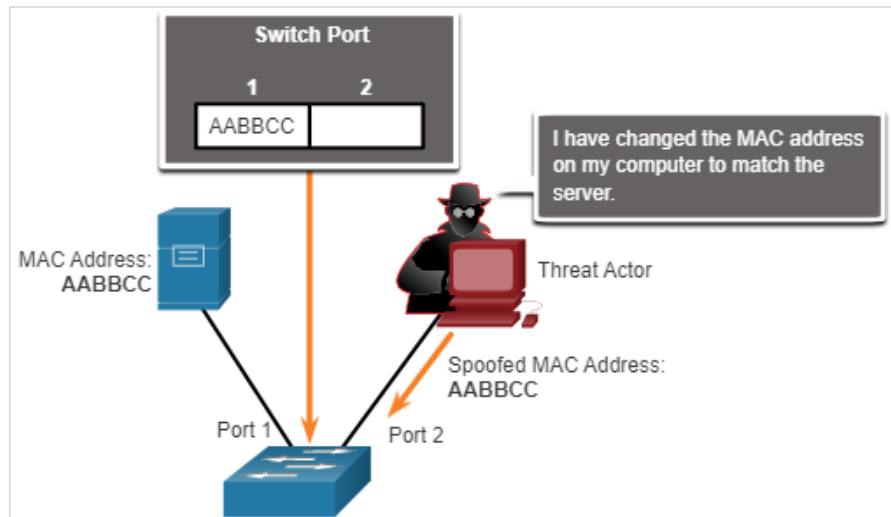
```
Switch(config)#  
ip arp inspection validate {[src-mac] [dst-mac] [ip [allow-zeros] ]}
```



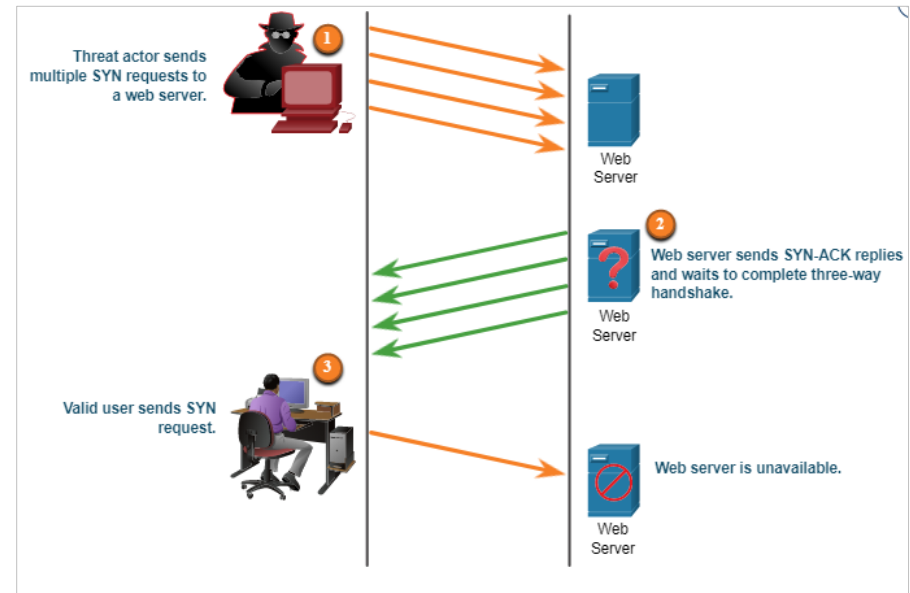
```
SwitchA(config)# ip arp inspection vlan 10
SwitchA(config)# interface gigabitEthernet 1/1
SwitchA(config-if)# ip arp inspection trust

SwitchB(config)# ip arp inspection vlan 10
SwitchB(config)# interface gigabitEthernet 1/1
SwitchB(config-if)# ip arp inspection trust
```

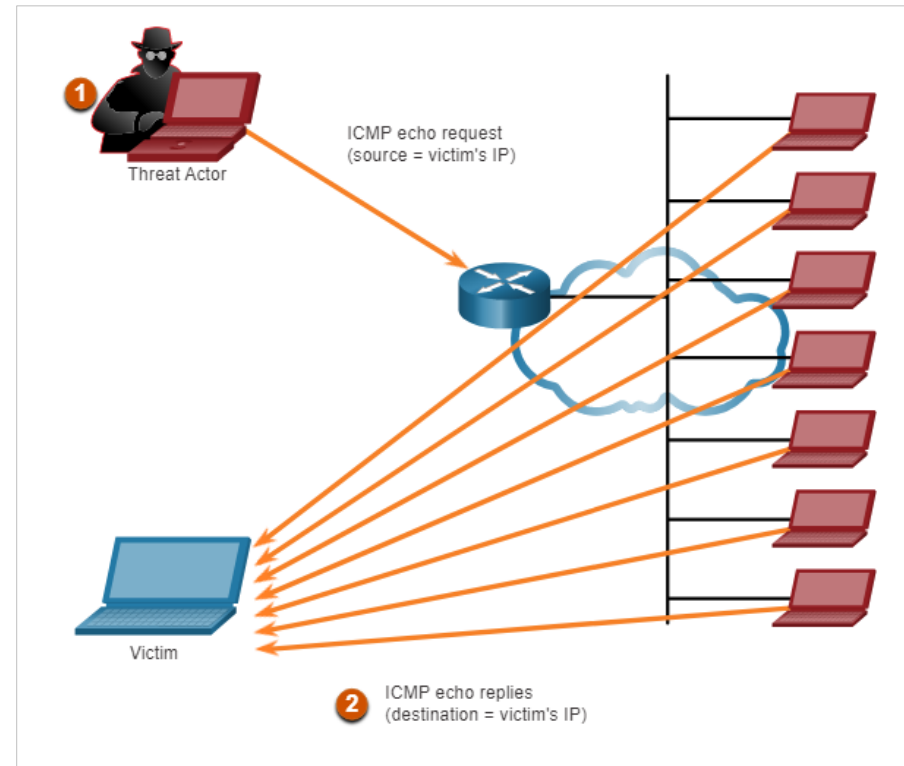
OTHER ATTACKS

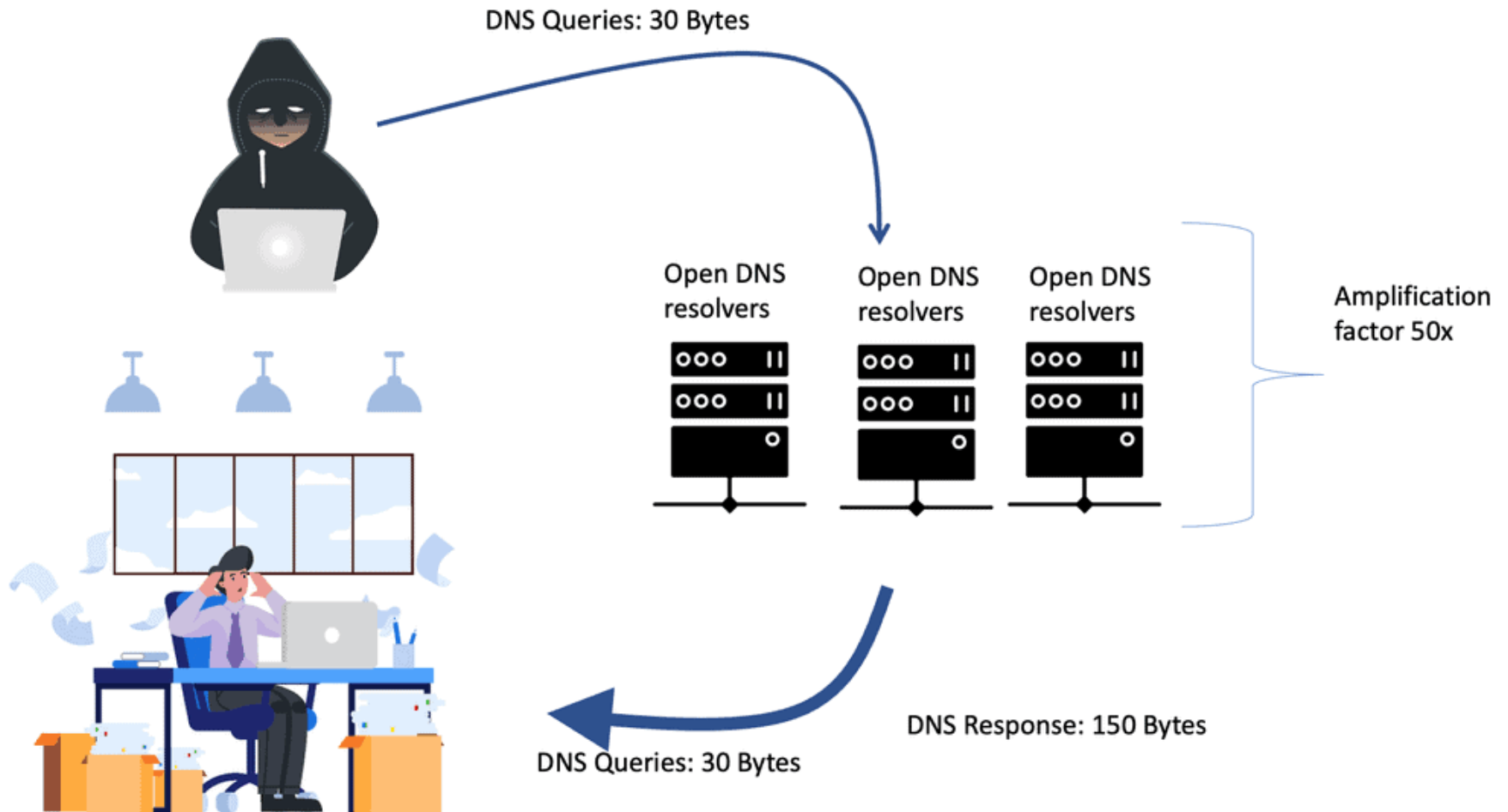


- Network applications use TCP or UDP ports. Threat actors conduct port scans of target devices to discover which services they offer.
- The **TCP SYN Flood attack** exploits the TCP three-way handshake.
 - The figure shows a threat actor continually sending TCP SYN session request packets with a randomly spoofed source IP address to a target.
 - The target replies with a TCP SYN-ACK packet to the spoofed IP address and waits for a TCP ACK packet. Those responses never arrive.
 - The target host has too many half-open TCP connections, and TCP services are denied to legitimate users.



- Threat actors often use amplification and reflection techniques to create DoS attacks.
- The figure shows how an amplification and reflection technique called a **Smurf attack** is used to overwhelm a target host.
 - **Amplification** - The threat actor forwards ICMP echo request messages to many hosts. These messages contain the source IP address of the victim.
 - **Reflection** - These hosts all reply to the spoofed IP address of the victim to overwhelm it.
- Threat actors also use resource exhaustion attacks.
- **Note:** *Newer forms of amplification and reflection attacks such as DNS-based reflection and amplification attacks and Network Time Protocol (NTP) amplification attacks are now being used.*







NTP Reflection Attack

STEP
1



Attacker

Internet Protocol Version 4

Source IP: 1.2.3.4.

User Datagram Protocol

Destination port: ntp (123)

Network Time Protocol

Request code: MON_GETLIST_1 (42)

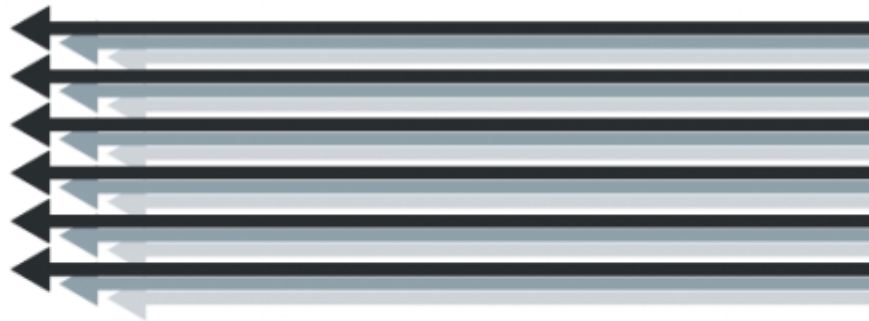


NTP Server

STEP
2



Victim (1.2.3.4)



NTP Server

Q & A

- Who is/are victim(s) in the case of CAM overflow attack/DHCP Spoofing/ARP MitM?
- How is L2 switch relaying traffic?
- What is Port Security? Explain its functionality.
- Describe DHCP and its functionality in detail.
- What is DHCP snooping. Explain its functionality.
- What parameters are assigned using DHCP? How long is the lease? Is it possible to assign same parameters to the same device/customer?
- Describe ARP and its functionality in detail.
- What is Dynamic ARP Inspection? Explain its functionality.
- Describe amplification and reflection attack type.

- LOMNICKÝ, Marek. *Analýza a demonstrace vybraných L2 útoků*. Online, Diplomová práce, vedoucí Ondřej Ryšavý. Brno: Vysoké učení technické v Brně. Fakulta informačních technologií. Ústav informačních systémů, 2009. Dostupné z: <http://hdl.handle.net/11012/53857>. [cit. 2025-03-23].

Vladimír Veselý veselyv@fit.vut.cz



- výzkumná skupina NES@FIT = specializace NNET
 - <https://www.fit.vut.cz/research/groups/nes@fit/>
- repa s různými projekty
 - <https://nesfit.github.io>
 - <https://git.fit.vutbr.cz/NESFIT>